CASE STUDY

The Year 2022 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2022 was the year a war arrived on the wire. In the six weeks before Russian tanks crossed into Ukraine, defenders found a wiper dressed as ransomware, then a second wiper signed with a certificate issued to Hermetica Digital Ltd, and in the early hours of 24 February an attack on a satellite network knocked tens of thousands of modems offline across Europe. Wipers kept coming, an attempt on high-voltage substations was analyzed by ESET working with CERT-UA, and in October a power company lost supply during missile strikes. Outside the war, the year's quieter story was identity: an extortion crew that worked through help desks and insiders, a wave of text-message phishing against staff, and a string of companies that learned their multi-factor prompts could be worn down or phished. Joint ransomware advisories came from CISA through most of the year, North Korean operators stole cryptocurrency at a scale that drew sanctions on the mixers that laundered it, and edge devices from VMware, Atlassian, F5, Fortinet, Citrix and Microsoft Exchange were exploited within days of disclosure or before it. Governments answered with a reporting law, a new directive on asset visibility, the first sanctions on a crypto mixer, and a proposed EU law on the security of products with digital elements.

This study is the dated record of that year. It is a chronicle, not a deep dive: where another study in this series is the home for an event, this one gives a paragraph and a link. The Ukraine grid attacks, Cyclops Blink, the Viasat attack and Prestige are told in the Sandworm study and the wider Russian record in the Russia-attributed actors study; the attack on Albania in the Iran-attributed actors study; the Ronin theft, TraderTraitor and Maui in the North Korea-attributed actors study; APT41's state-government campaign in the APT41 study; the second year of Log4Shell and the Cyber Safety Review Board's report in the Log4Shell study; and package-registry attacks, npm and PyPI, in the npm supply chain study. Everything else in 2022 that the verified record supports is here, in date order, with the source behind each line.

Evidence grade: the events, attributions, directives, sanctions and laws are **Confirmed** from the government agency, the victim, the vendor that observed the activity, the CVE, NVD and KEV records, or the MITRE record. Two statements that reached this study only through the library's own ATT&CK pages (that Industroyer2 had no impact, and that AcidRain caused the KA-SAT outage) are **Reported**. Checks this study re-ran against the library's ATT&CK, CWE and D3FEND data are **Demonstrated**. Where this study draws its own conclusion or maps behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2022, with lead-in events from 2020 and 2021 and later reports that describe 2022
Destructive malware against Ukraine	WhisperGate (13 Jan), HermeticWiper (23 Feb), IsaacWiper, HermeticWizard and CaddyWiper, per AA22-057A [17]; Industroyer2 set to run on 8 Apr [31]; Prestige ransomware on 11 Oct [64]; Microsoft counted more than 237 operations by at least six Russia-aligned actors and close to 40 destructive attacks by 27 April [36]
The satellite attack	KA-SAT, 24 Feb from about 03:02 UTC: a misconfigured VPN appliance, then management commands that overwrote modem flash; nearly 30,000 replacement modems shipped [19]; the EU, UK, US and allies named Russia on 10 May [6]
Government attributions	Russian military intelligence for the January defacements and WhisperGate and Russia for Viasat (NCSC, 10 May) [5]; Lazarus Group for Ronin (Treasury, 6 May) [24]; Iranian state actors for Albania (AA22-264A, 21 Sep), with OFAC citing actors assessed to be sponsored by Iran and the MOIS (9 Sep) and Microsoft assessing Iranian government sponsorship with high confidence (8 Sep) [46][76][45]; indictments of three FSB officers and a TsNIIKhM employee (24 Mar) [25]
Largest crypto thefts in the record	Ronin, almost $620 million (23 Mar) [24]; Wormhole, 120,000 unbacked wrapped ETH minted (2 Feb) [10]; BNB Chain, 2 million BNB withdrawn (October) [61]; Harmony's Horizon bridge (23 to 24 Jun) [40][49]
The identity front	Okta through a Sitel workstation (21 Jan) [9]; LAPSUS$ profiled by Microsoft (22 Mar) [23]; SMS phishing at Cloudflare (20 Jul) and Twilio (Aug) [48][42]; Cisco (24 May) [50]; Uber (15 Sep) [57]
KEV in 2022	555 entries added during the year, 91 of them CVE-2022 ids, 132 flagged for known ransomware use (computed from catalog version 2026.11.10) [27]
Most exploited in 2022	Older flaws more than new ones; the top 12 led by FortiOS CVE-2018-13379, ProxyShell, ManageEngine, Confluence and Log4Shell, per AA23-215A [87]
Policy landmarks	CIRCIA enacted (15 Mar) [102]; SEC proposed disclosure rules (9 Mar) [104]; OMB M-22-18 (14 Sep) [107]; Cyber Resilience Act proposed (15 Sep) [108]; BOD 23-01 (3 Oct) [109]; Executive Order 14086 (7 Oct) [110]; UK PSTI Act (6 Dec) [112]; Quantum Computing Cybersecurity Preparedness Act (21 Dec) [113]
ATT&CK during the year	v12 on 25 October added the Campaign object with 14 Enterprise campaigns [120]
This study's MITRE binding	116 Enterprise and 17 ICS technique rows, 56 group, software and campaign objects, 11 CWE rows with the library's CAPEC pairings, and two Navigator layers (Part 11)

Key findings

- **The war began with wipers, not with a cyber knockout.** WhisperGate appeared on 13 January, HermeticWiper on 23 February hours after DDoS attacks, and Microsoft saw a new round of destructive attacks several hours before the invasion (Confirmed [4][16][18]). None of these stopped the state from working; the record shows disruption, data destruction and an attack on satellite modems, not a collapse (Inferred from [36][19]).
- **The one attack felt across Europe hit a service provider's management plane.** At KA-SAT the attacker came in through a misconfigured VPN appliance and used legitimate management commands, so modems were wiped by the network that ran them (Confirmed [19]). Wind farms and internet users in central Europe were disrupted (Confirmed [6]).
- **Grid attacks were tried twice.** Industroyer2 was set for 8 April; ESET, working with CERT-UA, attributed it to Sandworm with high confidence (Confirmed [31]); the library's ATT&CK page says it had no impact (Reported [131]). In October Sandworm used the utility's own SCADA software to cause an outage that coincided with missile strikes, then wiped IT systems (Confirmed [63]). Living off the land had reached OT (Inferred).
- **Identity was the front door for several of the year's best-known breaches (Inferred).** LAPSUS$ used bought credentials, repeated MFA prompts, SIM swapping, help-desk social engineering and paid insiders, and deployed no ransomware (Confirmed [23]). Uber, Cisco and Twilio were reached through employees and contractors, not through software flaws (Confirmed [57][50][42]). Cloudflare's hardware security keys held when three employees entered credentials (Confirmed [48]).
- **Edge devices were exploited faster than they could be patched.** VMware's April fixes were reverse engineered and exploited within 48 hours (Confirmed [29][30]); Confluence, FortiOS, Citrix and Exchange flaws were exploited as zero-days or close to it (Confirmed [38][62][71][72][59]).
- **Old flaws were exploited more than new ones.** AA23-215A says actors exploited older vulnerabilities more than new ones in 2022, and Log4Shell drew high interest through the first half of the year (Confirmed [87]). Albania's attackers got in through a 2019 SharePoint flaw (Confirmed [45]).
- **Dwell time was measured in seasons.** Iran's actors were in Albania's networks about 14 months before the July attack (Confirmed [46]); a Defense Industrial Base victim held intruders for about a year (Confirmed [2]); APT41 re-compromised state-government victims in late February 2022 (Confirmed [21]).
- **Crypto theft became a sanctions target.** Treasury sanctioned the first mixer (Blender.io) and then Tornado Cash, which it said laundered over $455 million stolen by Lazarus Group (Confirmed [24][49]).
- **From June to December, CISA and partners published at least one joint ransomware advisory every month.** They covered Karakurt, MedusaLocker, Maui, Zeppelin, Vice Society, Daixin, Hive and Cuba (Confirmed [81][43][44][51][55][66][69][70]); Hive alone had more than 1,300 victims and about US$100 million in payments from June 2021 to November 2022 (Confirmed [69]).

Top recommendations

1. **Make MFA phishing-resistant before you make it universal.** The year's identity breaches beat push prompts, SIM-swapped phone numbers and fail-open configurations; FIDO2 keys held at Cloudflare, and Twilio adopted them afterward (Confirmed [48][42][22]; CISA's guidance [117]).

2. **Treat edge and management appliances as tier-zero assets on the KEV clock.** Patch internet-facing VPN, collaboration and identity products within days, and assume a device left unpatched past a known exploitation date is compromised, as CISA said for VMware Horizon (Confirmed [41][29]).
3. **Review who can reach your management plane.** KA-SAT's management segment, Okta's support tooling and MSP trust relationships show how one foothold can reach many customers (Confirmed [19][9][118]); every path into a management segment needs an owner, MFA and a review date (Inferred).
4. **Hunt for long dwell, not just new alerts.** Fourteen months in Albania and a year at a defense contractor were found late (Confirmed [46][2]); retrospective hunting found the federal Log4Shell compromise in AA22-320A (Confirmed [68]).
5. **Plan for destruction, not only for encryption.** Offline, immutable, tested backups and offline installation media are the controls the wiper and ransomware advisories share (Confirmed [17][69][70]).
6. **Lock down the developer and CI estate.** OAuth tokens, CI configuration variables, source repositories and vault backups in cloud storage were each a path to customer data this year (Confirmed [95][96][54][98]).

Scope and method

This study covers intrusions, exploited vulnerabilities, crime and the government response in calendar year 2022. It draws on CISA, FBI, NSA and partner advisories and directives, the UK NCSC and FCDO, Treasury, State Department, White House, FinCEN, FTC, SEC and OAIC releases, the FSB's own statement, the victims' own statements (ICRC, Okta, Viasat, Wormhole, Harmony, Cloudflare, Twilio, Uber, Twitter, LastPass, GitHub, Heroku, Slack, PyTorch, Optus, BNB Chain), the vendors that observed the activity (Microsoft, Mandiant, Google TAG, ESET, Cisco Talos, CrowdStrike), the vendor advisories (Atlassian, Spring, VMware, Fortinet, Citrix, OpenSSL), the CVE, NVD and KEV records, the CWE Top 25, the live MITRE ATT&CK pages and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words. Tradecraft is described at the level the advisories use, by technique name and id; no exploit details, commands or ransom notes are reproduced.

Grade	Meaning
Confirmed	A primary source was opened: the agency, the victim, the vendor that observed the activity, a CVE, NVD or KEV record, or the MITRE record itself
Reported	Known only through a secondary source whose original was not opened, such as a news report, or a statement this study read only on a library page
Demonstrated	A reproduction exists: researchers showed the flaw working, or this study re-ran the check against the library's data files
Inferred	This study's own reasoning from the cited facts, labelled where it appears

How the record is routed:

- **Home studies.** Where another study in this series is the home for an event, this study gives one paragraph and a link. The home studies are named in the executive summary.

- **Attribution language.** Each source's confidence words ("almost certainly", "high confidence", "very likely", "assessed", "believes") are carried through as written. A vendor's name for a group (DEV-0586, ACTINIUM, IRIDIUM, DEV-0537, NOBELIUM, EUROPIUM) is used with the vendor's report; its ATT&CK group is given through the alias table in the library's data, and where the source itself does not name the ATT&CK group, the link is marked as the library's alias or Inferred.
- **Victim beliefs.** A victim's statement that it "believes" an actor was responsible (Uber on LAPSUS$) is the victim's belief, not a finding, and is reported as such (Confirmed [57]).
- **Cumulative counts.** CISA's ransomware advisories give totals over several years (Hive since June 2021, Cuba to August 2022, Zeppelin since 2019); they are not 2022-only figures (Confirmed [69][70][51]).
- **KEV dates.** A KEV date-added value is the day CISA listed the CVE, not the day it was first exploited. The March 2022 spike of 226 additions, 95 of them on 3 March and 66 on 25 March, is backfill of older exploited CVEs into a catalog launched in November 2021, not a surge in new exploitation (Confirmed for the counts [27]; Inferred for the reading). Two CVE-2022 ids, ManageEngine CVE-2022-47966 and FortiOS CVE-2022-41328, belong to 2023: NVD published the first on 18 January 2023 and KEV listed it on 23 January 2023, and KEV listed the second on 14 March 2023 (Confirmed [94][27]).
- **ATT&CK versions.** The 2022 advisories print ATT&CK v10 and v11 ids. This study maps them to v20.0 through the library's `superseded_by.jsonl`; revoked ids are named where they are replaced (Demonstrated [122]).
- **What was not checked.** The following reported events and documents were not opened at a primary source during the research and are left out of the dated record: the Rackspace hosted Exchange incident (December); the LAPSUS$ data thefts at NVIDIA and Samsung and the LAPSUS$ arrests; the Toyota supplier stoppage (March); Ronin's own statement and the FBI's Lazarus statements on Ronin and Harmony; the Costa Rica emergency decree and the Hive attack on the CCSS; the victims' own statements at Los Angeles Unified, CommonSpirit Health and AIIMS Delhi; the FTX theft; the Killnet DDoS waves beyond the AA22-110A mention; the DOJ releases on the Cyclops Blink botnet disruption, Hydra, RaidForums, SSNDOB and a LockBit affiliate arrest; the Europol FluBot and iSpoof releases; the EU Council declaration on Viasat; the White House statement on Albania; NSA's advisory on Citrix ADC; Medibank's and Optus's own incident pages beyond the Optus release cited here; SentinelLabs' AcidRain analysis; the Conti leaks; and the attacks on Iranian steel plants. Their absence here is a gap in what was opened, not a judgment on what happened.

Part 1: the year at a glance

One row per dated event or report. Grades and sources are given on each row; later Parts tell the longer stories. "Unnamed" means the verified record names no actor.

Date	Event	Who (as the source names them)	Grade and source
2020-01 to 2022-02	US cleared defense contractors targeted regularly (AA22-047A, published 16 Feb 2022)	Russian state-sponsored actors	Confirmed [12]

Date	Event	Who (as the source names them)	Grade and source
Since at least 2020	Trojanized cryptocurrency applications used against blockchain companies (TraderTraitor, published 18 Apr 2022)	North Korean state-sponsored actors tracked as Lazarus Group, APT38, BlueNoroff and Stardust Chollima	Confirmed [34]
2021-01 to 2022-01	Access to a Defense Industrial Base organization's network through Exchange and valid accounts, with Impacket and a custom exfiltration tool; CISA responds from November 2021 through January 2022 (AA22-277A, published 4 Oct 2022)	APT actors	Confirmed [2]
2021-05	An NGO account with default MFA settings used to enroll a new MFA device; PrintNightmare exploited (AA22-074A, published 15 Mar 2022)	Russian state-sponsored actors	Confirmed [22]
2021-05	APT41's campaign against at least six US state government networks begins (ATT&CK C0017)	APT41	Confirmed [21]
2021-05	Likely initial access to Albanian government networks through SharePoint CVE-2019-0604	DEV-0861 (Microsoft); Iranian state actors (AA22-264A)	Confirmed [45][46]
2021-10	Ukrainian organizations critical to emergency response and territorial security targeted from October 2021	ACTINIUM (Gamaredon), attributed by Ukraine to the FSB	Confirmed [11]
2021-11-09	Attackers enter ICRC servers through unpatched ManageEngine ADSelfService Plus CVE-2021-40539	Unnamed	Confirmed [1]
2021-12-28	Compile timestamp of HermeticWiper	Not attributed by ESET	Confirmed [16]
2022-01-04	Earliest evidence of exploitation of Chrome CVE-2022-0609	Two North Korean government-backed groups (Operation Dream Job, Operation AppleJeus)	Confirmed [3]
2022-01-11	AA22-011A on Russian state-sponsored threats to US critical infrastructure, naming APT29, APT28 and Sandworm Team	CISA, FBI, NSA	Confirmed [74]
2022-01-13	WhisperGate first appears on Ukrainian systems; Ukrainian government websites defaced	DEV-0586 (Microsoft, no known link at the time); Russian military intelligence "almost certainly involved" (NCSC, 10 May)	Confirmed [4][5]
2022-01-14	FSB announces it stopped the REvil community: 25 addresses, 14 members, more than 426 million rubles seized, acting on a US appeal	REvil members	Confirmed [8]

Date	Event	Who (as the source names them)	Grade and source
2022-01-15	Microsoft discloses WhisperGate as destructive, not ransomware	DEV-0586, now Cadet Blizzard	Confirmed [4]
2022-01-16 to 01-21	Access to the Sitel environment; one support engineer's workstation controlled for 25 minutes on 21 January; two Okta customer tenants accessed	Unnamed	Confirmed [9]
2022-01-18	ICRC determines its servers were compromised; data of more than 515,000 people affected	Unnamed	Confirmed [1]
2022-02-02	Wormhole bridge: a signature verification flaw used to mint 120,000 unbacked wrapped ETH, 93,750 bridged back to Ethereum	Unnamed	Confirmed [10]
2022-02-04	Microsoft profiles ACTINIUM's campaign against Ukraine	ACTINIUM (Gamaredon)	Confirmed [11]
2022-02-09	AA22-040A on 2021 ransomware trends: RaaS grows, payment negotiators and help centres appear	CISA, FBI, NSA, Australian and UK partners	Confirmed [79]
2022-02-10 to 02-14	Google TAG discovers the Chrome zero-day exploitation; Google patches it on 14 February in 98.0.4758.102; KEV lists it on 15 February	North Korean government-backed groups	Confirmed [3][89][27]
2022-02-16	AA22-047A on targeting of cleared defense contractors	Russian state-sponsored actors	Confirmed [12]
2022-02-23	Cyclops Blink exposed as Sandworm's replacement for VPNFilter, deployed since at least June 2019 mainly on WatchGuard devices	Sandworm (NCSC, CISA, FBI, NSA)	Confirmed [13][14][15]
2022-02-23	HermeticWiper hits hundreds of computers in Ukrainian organizations hours after DDoS attacks take Ukrainian websites offline	Not attributed by ESET	Confirmed [16]
2022-02-24	KA-SAT attack from about 03:02 UTC; modems drop off from about 04:15 UTC	Not named by Viasat; Russia per the 10 May attribution	Confirmed [19][6]
2022-02-24	MSTIC detects a new round of destructive attacks several hours before the invasion and names FoxBlade	Unnamed	Confirmed [18]
2022-02-24	AA22-055A: MuddyWater is a subordinate element of Iran's MOIS	FBI, CISA, CNMF, NCSC-UK, NSA	Confirmed [20]
2022-02-26	AA22-057A on destructive malware against Ukraine; updated 1 March and 28 April	Tagged Nation-State Actor: Russia	Confirmed [17]
2022-03-03 and 03-25	KEV adds 95 and then 66 entries, most of them older CVEs	CISA	Confirmed [27]

Date	Event	Who (as the source names them)	Grade and source
2022-03-08	Mandiant reports APT41 in at least six US state government networks through USAHerds CVE-2021-44207 and Log4j	APT41	Confirmed [21]
2022-03-09	SEC proposes cybersecurity incident and governance disclosure rules	SEC	Confirmed [104]
2022-03-15	CIRCIA enacted as Division Y of the Consolidated Appropriations Act, 2022; AA22-074A published	US Congress; CISA	Confirmed [102][22]
2022-03-21	The President urges critical infrastructure owners to harden immediately, citing evolving intelligence on Russian options for cyberattacks	The White House	Confirmed [105]
2022-03-22	Microsoft profiles DEV-0537 (LAPSUS$); Okta's first estimate puts possible impact at 366 customers	DEV-0537	Confirmed [23][9]
2022-03-23	Almost $620 million stolen from a blockchain project linked to Axie Infinity (Ronin); Industroyer2 compiled	Lazarus Group (Treasury); Sandworm (ESET)	Confirmed [24][31]
2022-03-24	TAG publishes its Chrome zero-day report; DOJ unseals indictments of three FSB officers and a TsNIIKhM employee; AA22-083A covers their energy-sector campaigns of 2011 to 2018	North Korean groups; "state-sponsored Russian cyber actors"	Confirmed [3][25]
2022-03-31	Spring announces the Spring Framework RCE CVE-2022-22965 that had leaked; fixes in 5.3.18 and 5.2.20; KEV lists it on 4 April	n/a	Confirmed [26][27]
2022-03	LockBit 3.0 emerges	LockBit	Confirmed [82]
2022-04-05	Treasury sanctions Hydra and Garantex; Germany's BKA shuts Hydra's servers	Hydra, Garantex	Confirmed [28]
2022-04-06	VMware patches CVE-2022-22954 and CVE-2022-22960; actors exploit them within 48 hours. Microsoft takes over seven STRONTIUM domains by court order	Unnamed; STRONTIUM (APT28)	Confirmed [29][30][90][75]
2022-04-07	A compromised machine-account token used to download Heroku customers' GitHub integration OAuth tokens	Unnamed	Confirmed [96]
2022-04-08	Industroyer2 scheduled to run at 16:10 UTC against high-voltage substations, CaddyWiper at 16:20 UTC	Sandworm (ESET, high confidence)	Confirmed [31]
2022-04-12	GitHub detects use of stolen OAuth user tokens issued to Heroku and Travis CI; ESET publishes Industroyer2	Unnamed; Sandworm	Confirmed [95][31]

Date	Event	Who (as the source names them)	Grade and source
2022-04-13	AA22-103A: custom tools against Schneider Electric and OMRON PLCs and OPC UA servers	APT actors (DOE, CISA, NSA, FBI)	Confirmed [33]
2022-04-14	OFAC adds an ETH address to the Lazarus Group SDN entry	Lazarus Group	Confirmed [78]
2022-04-18	AA22-108A on TraderTraitor	Lazarus Group, APT38, BlueNoroff	Confirmed [34]
2022-04-20	AA22-110A (Five Eyes) on Russian state and criminal threats; Okta concludes its investigation at two tenants	FSB, SVR, GRU units; Killnet, Wizard Spider; Okta	Confirmed [35][9]
2022-04	Conti ransomware disrupts the Costa Rican government's customs and tax platforms	Conti (State Department)	Confirmed [32]
2022-04-27	Microsoft reports more than 237 operations against Ukraine; AA22-117A lists the top routinely exploited CVEs of 2021	At least six Russia-aligned actors; seven Five Eyes agencies	Confirmed [36][88]
2022-05-05	NVD publishes F5 BIG-IP CVE-2022-1388; KEV lists it on 10 May with known ransomware use	n/a	Confirmed [91]
2022-05-06	Treasury sanctions Blender.io, the first mixer sanctioned; the State Department offers up to $10 million for Conti leaders	Lazarus Group proceeds; Conti	Confirmed [24][32]
2022-05-09	Microsoft profiles the RaaS economy	DEV-0193, ELBRUS, DEV-0237, DEV-0401, DEV-0537	Confirmed [80]
2022-05-10	The EU, UK, US and allies say Russia was behind the Viasat attack; NCSC assesses Russian military intelligence almost certainly involved in the January defacements and WhisperGate	Russia	Confirmed [6][5]
2022-05-11	AA22-131A warns of attacks on MSPs and their customer trust relationships	Five Eyes and JCDC	Confirmed [118]
2022-05-18	ED 22-03 for VMware; AA22-138B on exploitation within 48 hours	CISA	Confirmed [29][30]
2022-05-24	Cisco becomes aware of a potential compromise, entered through an employee's personal Google account and VPN	An initial access broker tied to UNC2447, LAPSUS$ and Yanluowang (Talos, moderate to high confidence)	Confirmed [50]
2022-05-30	Heroku concludes its investigation; hashed customer passwords were also taken	Unnamed	Confirmed [96]
2022-06-01	NVD publishes Follina, CVE-2022-30190; AA22-152A on Karakurt	n/a; Karakurt	Confirmed [37][81]

Date	Event	Who (as the source names them)	Grade and source
2022-06-02	Atlassian discloses active exploitation of Confluence CVE-2022-26134; KEV lists it the same day	Credited to Volexity for discovery	Confirmed [38][27]
2022-06-07	AA22-158A: telecommunications companies and network service providers compromised through network-device CVEs	PRC state-sponsored actors	Confirmed [39]
2022-06 or earlier	Sandworm inside a Ukrainian power company (ATT&CK C0034, June to October)	Sandworm	Confirmed [63][119]
2022-06-23	Harmony's Horizon bridge drained from 05:30 PST; AA22-174A on continued Log4Shell exploitation of VMware Horizon	Unnamed by Harmony; CISA and USCG	Confirmed [40][41]
2022-06-29	Vishing incident at Twilio exposes customer contact information	Likely the same actors as August (Twilio)	Confirmed [42]
2022-06-30	AA22-181A on MedusaLocker	MedusaLocker actors	Confirmed [43]
2022-07-06	AA22-187A on Maui ransomware against healthcare	North Korean state-sponsored actors	Confirmed [44]
2022-07-11	The Cyber Safety Review Board's first report calls Log4j an endemic vulnerability	CSRB	Confirmed [106]
2022-07-15	Destructive attack on the Albanian government, claimed on 18 July as HomeLand Justice	Iranian government-sponsored actors (Microsoft, high confidence)	Confirmed [45][46]
2022-07-20	At least 76 Cloudflare employees receive SMS phishing to a fake Okta page	Unnamed	Confirmed [48]
2022-07	Twitter learns that data compiled through a 2021 bug is offered for sale	Unnamed seller	Confirmed [47]
2022-08-02	Nomad bridge heist	Unnamed	Confirmed [49]
2022-08-04 to 08-09	Twilio aware of SMS phishing access on 4 August; last activity 9 August	Unnamed	Confirmed [42]
2022-08	Exchange CVE-2022-41040 and CVE-2022-41082 chained against fewer than 10 organizations	One likely state-sponsored group (Microsoft, medium confidence)	Confirmed [59]
2022-08-08	Treasury sanctions Tornado Cash	Lazarus Group proceeds	Confirmed [49]
2022-08-10	Cisco Talos publishes its incident report	As above	Confirmed [50]
2022-08-11	AA22-223A on Zeppelin; KEV lists Zimbra CVE-2022-27925	Zeppelin RaaS	Confirmed [51][27]
2022-08-16	AA22-228A on exploited Zimbra flaws	n/a	Confirmed [52]

Date	Event	Who (as the source names them)	Grade and source
2022-08-24	Microsoft discloses MagicWeb on AD FS servers	NOBELIUM	Confirmed [53]
2022-08-25	LastPass discloses a development-environment intrusion with source code taken	Unnamed	Confirmed [54]
2022-09-06	AA22-249A on Vice Society against education	Vice Society	Confirmed [55]
2022-09-08 to 09-09	Microsoft attributes the Albania attack to Iran; OFAC sanctions the MOIS and its minister	Iran, MOIS	Confirmed [45][76]
2022-09	Second wave against Albania, likely retaliation for attribution; LockBit's builder leaks	Iranian state actors; LockBit	Confirmed [46][82]
2022-09-14	AA22-257A on IRGC-affiliated extortion; Treasury sanctions 10 individuals and 2 entities; OMB M-22-18	IRGC-affiliated actors	Confirmed [56][77][107]
2022-09-15	Uber breach through a contractor's account; the European Commission proposes the Cyber Resilience Act	Believed by Uber to be LAPSUS$-affiliated	Confirmed [57][108]
2022-09-21	AA22-264A on the Albania campaign	Iranian state cyber actors	Confirmed [46]
2022-09-22	Optus breach made public	Unnamed	Confirmed [58][100]
2022-09-24	SOCRadar reports a misconfigured Microsoft storage endpoint	n/a	Confirmed [99]
2022-09-30	Microsoft analyzes the Exchange zero-days; KEV lists both	As above	Confirmed [59][27]
2022-10-03	BOD 23-01 on asset visibility and vulnerability detection	CISA	Confirmed [109]
2022-10-06	AA22-279A on the top CVEs used by PRC state-sponsored actors since 2020	NSA, CISA, FBI	Confirmed [60]
2022-10-07	Executive Order 14086 on signals intelligence safeguards	The White House	Confirmed [110]
2022-10	BNB Chain's BSC Token Hub bridge exploited through a forged proof; 2 million BNB withdrawn (exact day not in the extract)	Unnamed	Confirmed [61]
2022-10-10	Fortinet publishes FG-IR-22-377 (CVE-2022-40684), aware of exploitation; Sandworm causes a power outage in Ukraine through SCADA software	Unnamed; Sandworm	Confirmed [62][63]

Date	Event	Who (as the source names them)	Grade and source
2022-10-11	Prestige ransomware deployed within an hour across victims in Ukraine and Poland	IRIDIUM (Seashell Blizzard), "very likely"	Confirmed [64]
2022-10-12	A new CaddyWiper variant deployed in the power company's IT environment	Sandworm	Confirmed [63]
2022-10	Medibank data breach affecting 9.7 million Australians	Ransomware actor later sanctioned (2024)	Confirmed [65][83]
2022-10-19	MSRC confirms the misconfigured endpoint and says SOCRadar overstated the scope	Microsoft	Confirmed [99]
2022-10-21	AA22-294A on Daixin Team against healthcare	Daixin Team	Confirmed [66]
2022-10-24	FTC order against Drizly and its CEO	FTC	Confirmed [101]
2022-10-25	ATT&CK v12 adds the Campaign object	MITRE	Confirmed [120]
2022-10-31 to 11-01	Second International Counter Ransomware Initiative summit; 36 countries and the EU set up a task force	CRI members	Confirmed [85]
2022-11-01	OpenSSL fixes CVE-2022-3602 and CVE-2022-3786, rated High after a Critical pre-announcement; FinCEN reports 2021 ransomware filings near US$1.2 billion	OpenSSL; FinCEN	Confirmed [67][84]
2022-11-16	AA22-320A on a federal agency compromised through Log4Shell	Iranian government-sponsored actors	Confirmed [68]
2022-11-17	AA22-321A on Hive	Hive actors	Confirmed [69]
2022-12-01	AA22-335A on Cuba ransomware	Cuba actors	Confirmed [70]
2022-12-06	UK Product Security and Telecommunications Infrastructure Act enacted	UK Parliament	Confirmed [112]
2022-12-12	Fortinet discloses FortiOS SSL-VPN CVE-2022-42475, exploited in the wild; KEV lists it on 13 December	Unnamed	Confirmed [71][27]
2022-12-13	Citrix fixes CVE-2022-27518, citing limited targeted attacks; KEV lists it the same day	Unnamed (NSA's related advisory not opened)	Confirmed [72][93]
2022-12-20	CrowdStrike describes OWASSRF in Play ransomware intrusions	Play ransomware actors (CrowdStrike)	Confirmed [92]
2022-12-21	Quantum Computing Cybersecurity Preparedness Act becomes law	US Congress	Confirmed [113]
2022-12-22	LastPass says a backup of customer vault data was copied from cloud storage	Unnamed	Confirmed [54]
2022-12-25 to 12-30	torchtriton dependency-confusion package hits PyTorch nightly installs on Linux	Unnamed	Confirmed [97]

Date	Event	Who (as the source names them)	Grade and source
2022-12-27	Stolen Slack employee tokens used to download private GitHub repositories (disclosed 31 Dec)	Unnamed	Confirmed [98]
After the year	TAG's 2022 review (16 Feb 2023); Microsoft's Cadet Blizzard report (14 Jun 2023); AA23-165A on LockBit and AA23-215A on 2022's top exploited CVEs; Medibank sanctions (23 Jan 2024) and OAIC action (5 Jun 2024)	Various	Confirmed [73][7][82][87][83][65]

Part 2: Russia and the war in Ukraine

The home for Sandworm's operations of 2022 is the Sandworm study, and for the wider Russian record the Russia-attributed actors study. This Part gives the dated sequence.

January: the first wiper. On 13 January destructive malware appeared on systems in Ukraine. It overwrites the master boot record with a fake ransom note and then corrupts files, and Microsoft judged it destructive, not a real ransom operation; at publication on 15 January Microsoft tracked the actor as DEV-0586 and found no link to any known group (Confirmed [4]). In June 2023 Microsoft assessed that Cadet Blizzard, formerly DEV-0586, is "associated with" the GRU, created and deployed WhisperGate, is linked to the mid-January defacements, is "almost certainly linked" to the Free Civilian leak site, and peaked from January to June 2022 (Confirmed [7]). In ATT&CK the group is G1003 Ember Bear, with DEV-0586 and Cadet Blizzard among its aliases, and the malware is S0689 WhisperGate (Confirmed [7][124]). On 10 May the UK NCSC assessed that Russian military intelligence was "almost certainly involved" in the 13 January defacements and the WhisperGate deployment (Confirmed [5]).

February: espionage, then destruction. Microsoft reported on 4 February that ACTINIUM (G0047 Gamaredon Group) had targeted Ukrainian government, military, NGO, judiciary and law-enforcement organizations since October 2021; Microsoft says the Ukrainian government publicly attributed the group to the FSB and that it saw the group operating from Crimea (Confirmed [11]). On 23 February, ESET detected HermeticWiper on hundreds of computers in several Ukrainian organizations, hours after DDoS attacks took Ukrainian websites offline (Confirmed [16]). The sample had a compile timestamp of 28 December 2021, abused legitimate EaseUS Partition Master drivers and was signed with a certificate issued to Hermetica Digital Ltd; ESET named no actor (Confirmed [16]). Microsoft said that several hours before missiles and tanks moved on 24 February, MSTIC detected a new round of destructive attacks against Ukraine's digital infrastructure and named new malware FoxBlade (Confirmed [18]). AA22-057A, first published on 26 February and updated on 1 March and 28 April, lists WhisperGate, HermeticWiper, IsaacWiper, HermeticWizard and CaddyWiper as deployed against Ukraine since January, tagged Nation-State Actor: Russia (Confirmed [17]).

Cyclops Blink. On 23 February the NCSC, CISA, FBI and NSA exposed Cyclops Blink (S0687), a Sandworm (G0034) framework that replaced VPNFilter (S1010), deployed as a fake firmware update since at least June 2019, mainly on WatchGuard devices whose remote management was exposed; the US and UK had already attributed Sandworm to the GRU's GTsST (Confirmed [13][14]). WatchGuard provided detection and removal tooling (Confirmed [15]).

24 February: KA-SAT. Viasat reported that the attack began around 03:02 UTC on 24 February and that modems dropped off from about 04:15 UTC (Confirmed [19]). The attacker exploited a misconfigured VPN appliance to reach the trusted management segment of the KA-SAT network, then sent legitimate management commands to large numbers of residential modems, overwriting key data in flash so they could no longer reach the network; the modems were recoverable by factory reset (Confirmed [19]). Viasat says several thousand customers in Ukraine and tens of thousands elsewhere in Europe were affected and that nearly 30,000 replacement modems were shipped; it names no attacker and no malware (Confirmed [19]). On 10 May the EU, UK, US and allies announced that Russia was behind the attack, which disrupted wind farms and internet users in central Europe; the NCSC judged it "almost certain" that Russia was responsible and believes the primary target was the Ukrainian military (Confirmed [6][5]). The library's S1125 AcidRain page ties the AcidRain modem wiper to the KA-SAT outage, with overlap with VPNFilter (Reported [128]); the SentinelLabs analysis behind that tie was not opened, so the link from AcidRain to Viasat rests on the ATT&CK record, not on a primary opened here.

April: the grid, the domains and the count. On 6 April Microsoft obtained a court order to take over seven domains used by STRONTIUM (G0007 APT28), which it describes as connected to the GRU, used against Ukrainian institutions including media and against US and EU foreign-policy targets; it had used the same legal process 15 times before, seizing more than 100 domains since 2016 (Confirmed [75]). Industroyer2 (S1072), compiled on 23 March, was set to run at 16:10 UTC on 8 April against high-voltage substations of a Ukrainian energy provider, with CaddyWiper (S0693) set for 16:20 UTC on the same machine; the ORCSHRED, SOLOSHRED and AWFULSHRED wipers were also deployed, Industroyer2 speaks IEC-104 only, and ESET, working with CERT-UA, assessed "with high confidence" that Sandworm was responsible (Confirmed [31]). The library's S1072 page says it was discovered before deploying, with no impact (Reported [131]). On 20 April the Five Eyes advisory AA22-110A assessed BERSERK BEAR as "almost certainly FSB's Center 16", tied APT28 to GRU GTsSS Unit 26165 and Sandworm to GTsST Unit 74455, named Killnet, WIZARD SPIDER (Conti) and MUMMY SPIDER (Emotet) among the aligned criminal groups, and stated that the authoring agencies had not attributed Gamaredon or Turla to the Russian government (Confirmed [35]). On 27 April Microsoft counted more than 237 operations by at least six Russia-aligned nation-state actors, close to 40 destructive attacks on hundreds of systems, and pre-positioning as early as March 2021; it attributed the wiper attacks it had previously disclosed to "a Russian nation-state actor we call Iridium" (Confirmed [36]).

October: the outage and Prestige. Mandiant reports that Sandworm was inside a Ukrainian power company from June 2022 or earlier (Confirmed [63]). On 10 October it used the native MicroSCADA `scilc.exe` binary to issue unauthorized commands, causing an unplanned outage that coincided with mass missile strikes, and on 12 October it deployed a new CaddyWiper variant in IT (Confirmed [63]). ATT&CK records this as C0034, the 2022 Ukraine Electric Power Attack, June to October 2022, with GOGETTER, Neo-REGEORG and CaddyWiper (Confirmed [119][129]). On 11 October Prestige ransomware (S1058) hit transportation and logistics organizations in Ukraine and Poland, all within an hour; Microsoft's November update says IRIDIUM, which publicly overlaps Sandworm and is now Seashell Blizzard, "very likely" executed the attacks (Confirmed [64]).

Beyond Ukraine. AA22-011A of 11 January described Russian state-sponsored threats to US critical infrastructure, naming APT29 (G0016), APT28 and Sandworm Team (Confirmed [74]). AA22-047A said that from at least January 2020 through February 2022 Russian state-sponsored actors regularly targeted US cleared defense contractors (Confirmed [12]). AA22-074A described a Russian intrusion at an NGO from as

early as May 2021: a dormant account that had been unenrolled from Duo but not disabled in Active Directory was password-guessed, a new MFA device enrolled, PrintNightmare (CVE-2021-34527) exploited, and MFA made to fail open (Confirmed [22]). On 24 March DOJ unsealed indictments of three FSB officers and a TsNIIKhM employee, and AA22-083A described the FSB's global energy campaign of 2011 to 2018, including Havex and the 2016 to 2018 targeting of US energy (G0035 Dragonfly), and the 2017 TRITON operation at a Middle East refinery (G0088 TEMP.Veles) (Confirmed [25]). On 24 August Microsoft disclosed MagicWeb, a highly targeted NOBELIUM post-compromise capability on AD FS servers found during an incident response (Confirmed [53]); NOBELIUM is an alias of APT29 in the library's data, and the SolarWinds campaign that made the name is told in the SolarWinds study (Confirmed [124]). Google TAG later reported that in 2022 Russia increased its targeting of users in Ukraine by 250% compared with 2020 and of users in NATO countries by over 300% (Confirmed [73]).

Part 3: Iran, North Korea and China

Iran: MuddyWater. AA22-055A of 24 February, from the FBI, CISA, CNMF, NCSC-UK and NSA, states that MuddyWater (G0069) is "a subordinate element within" Iran's Ministry of Intelligence and Security, conducting espionage against telecommunications, defense, local government and oil and gas organizations in Asia, Africa, Europe and North America (Confirmed [20]). It names PowGoop (S1046), Small Sieve (S1035), Canopy, Mori (S1047) and POWERSTATS (S0223) (Confirmed [20]).

Iran: Albania. The home for this campaign is the Iran-attributed actors study. Microsoft assessed "with high confidence" that Iranian government-sponsored actors carried out a destructive attack on the Albanian government on 15 July; DEV-0861 likely gained access in May 2021 through SharePoint CVE-2019-0604, and Microsoft names DEV-0842 (ransomware and wiper), DEV-0861 (initial access and exfiltration), DEV-0166 and DEV-0133 (Confirmed [45]). With moderate confidence it links the access activity to EUROPIUM, which is publicly linked to the MOIS, and the wiper's license key ties it to ZeroCleare (Confirmed [45]). AA22-264A of 21 September says "Iranian state cyber actors" using the HomeLand Justice persona attacked after about 14 months of access, exfiltrated email, and used a ransomware-style encryptor (GoXML.exe) and a ZeroCleare-version wiper (S1151) with the RawDisk driver (S0364); the attack was claimed on 18 July, and a second wave in September was "likely" retaliation for public attribution and Albania severing diplomatic ties with Iran (Confirmed [46]). ATT&CK records the campaign as C0038 HomeLand Justice, and "Homeland Justice" is an alias of G1055 VOID MANTICORE in the library's data (Confirmed [124]). On 9 September OFAC sanctioned the MOIS and Minister of Intelligence Esmail Khatib under EO 13694, citing the attack by actors "assessed to be sponsored by the Government of Iran and MOIS" (Confirmed [76]).

Iran: the IRGC-affiliated extortion crew. AA22-257A of 14 September says IRGC-affiliated actors exploited Fortinet FortiOS and Exchange ProxyShell (CVE-2021-34473) flaws for data extortion and BitLocker disk encryption for ransom, including against a US police department (Confirmed [56]). The same day Treasury sanctioned 10 IRGC-affiliated individuals and 2 entities; it says they "do not directly align with a named advanced persistent threat group" and that their activity is partly attributable to APT35 and Charming Kitten, and an indictment of three of them was unsealed in New Jersey (Confirmed [77]). Charming Kitten and APT35 are aliases of G0059 Magic Hound in the library's data; Treasury cites no ATT&CK id, so the mapping is this study's (Inferred [77][124]). AA22-320A of 16 November adds that Iranian government-sponsored actors compromised a federal civilian agency through Log4Shell (Part 6).

North Korea: crypto theft and laundering. The home for this record is the North Korea-attributed actors study. Google TAG found two North Korean government-backed groups, which it tracks as Operation Dream Job and Operation AppleJeus, exploiting Chrome CVE-2022-0609 from 4 January against targets in US news media, IT, cryptocurrency and fintech (Confirmed [3]). Treasury says Lazarus Group (G0032) stole almost US$620 million on 23 March from a blockchain project linked to Axie Infinity (Ronin), and sanctioned Blender.io on 6 May for processing over US$20.5 million of it, the first mixer ever sanctioned (Confirmed [24]). On 14 April OFAC added an ETH address to the Lazarus Group SDN entry; the notice does not name Ronin, and the FBI statement on Ronin could not be opened (Confirmed [78]). AA22-108A of 18 April, from the FBI, CISA and Treasury, describes TraderTraitor: trojanized cross-platform cryptocurrency applications pushed through social engineering to staff at exchanges, DeFi, play-to-earn gaming and venture capital firms since at least 2020, by "North Korean state-sponsored" actors tracked as Lazarus Group, APT38 (G0082), BlueNoroff and Stardust Chollima (Confirmed [34]). On 8 August Treasury sanctioned Tornado Cash, which it said laundered more than US$7 billion since 2019, including over US$455 million stolen by Lazarus Group, over US$96 million from the 24 June Harmony bridge heist and at least US$7.8 million from the 2 August Nomad heist; the later legal history of that designation was not checked (Confirmed [49]).

North Korea: Maui. In AA22-187A of 6 July the FBI assesses that "North Korean state-sponsored cyber actors" have used Maui ransomware against Healthcare and Public Health organizations since at least May 2021, encrypting servers for healthcare services and sometimes disrupting services for long periods (Confirmed [44]). The library's ATT&CK data has no Maui software object (Confirmed [124]).

China. The home for APT41 is the APT41 study and for the wider record the China-attributed actors study. Mandiant reported on 8 March that APT41 (G0096), "a prolific Chinese state-sponsored espionage group", compromised at least six US state government networks between May 2021 and February 2022, through the USAHerds zero-day CVE-2021-44207 and Log4j, and re-compromised victims in late February 2022; the goals are unknown and PII was taken (Confirmed [21]). ATT&CK records it as C0017, with KEYPLUG (S1051) and DEADEYE (S1052) (Confirmed [21][124]). AA22-158A of 7 June says "PRC state-sponsored cyber actors" have exploited SOHO routers and NAS devices since 2020 and compromised major telecommunications companies and network service providers, dumping RADIUS credentials and mirroring traffic (Confirmed [39]). AA22-279A of 6 October lists the top CVEs used by PRC state-sponsored actors since 2020, led by Log4j CVE-2021-44228, Pulse CVE-2019-11510, GitLab CVE-2021-22205, Confluence CVE-2022-26134 and Exchange CVE-2021-26855; three of its 20 CVEs are from 2022: Confluence CVE-2022-26134, F5 BIG-IP CVE-2022-1388 and Apache APISIX CVE-2022-24112 (Confirmed [60]).

Unattributed APT activity. The Defense Industrial Base intrusion in AA22-277A is credited only to APT actors: access from mid-January 2021 to mid-January 2022 through Exchange and valid accounts, Impacket (S0357) and the custom CovalentStealer exfiltrating to OneDrive (Confirmed [2]). Microsoft attributed the August Exchange zero-days, with medium confidence, to a single likely state-sponsored group it did not name (Confirmed [59]).

Part 4: identity as the front door

Okta and Sitel. Okta's concluded investigation found that the actor had access to the Sitel environment from 16 to 21 January and controlled one support engineer's workstation for 25 consecutive minutes on 21 January, accessing two active customer tenants in the SuperUser application (Confirmed [9]). That was far below the 366 customers Okta first estimated on 22 March, and Okta ended its relationship with Sitel (Confirmed [9]).

LAPSUS$. Microsoft's profile of DEV-0537 on 22 March (G1004 LAPSUS$, later Strawberry Tempest) describes pure extortion and destruction without ransomware (Confirmed [23]). Initial access came from bought credentials and the RedLine stealer (S1240), purchased session tokens, MFA prompt spamming, SIM swapping, help-desk social engineering and paid insiders; in cloud tenants the actor created global admins, set mail transport rules to forward mail, removed other admins, and joined victims' incident calls (Confirmed [23]). At Microsoft a single account was compromised with limited access and portions of source code were taken, with no customer code or data involved (Confirmed [23]).

Cisco. Cisco Talos said Cisco became aware of a potential compromise on 24 May; initial VPN access came through an employee's compromised personal Google account, and the actor was linked with moderate to high confidence to an initial access broker with ties to UNC2447, LAPSUS$ and Yanluowang (Confirmed [50]).

The SMS phishing wave. On 20 July, from 22:50 UTC, at least 76 Cloudflare employees received text messages pointing to a fake Okta login page on a lookalike domain within under a minute; three entered credentials, but origin-bound FIDO2 hardware keys stopped the intrusion, and Cloudflare links the attack to the Twilio incident (Confirmed [48]). Twilio became aware on 4 August of access gained by SMS phishing of employees and saw the last activity on 9 August; its final count was 209 of over 270,000 customers and 93 of about 75 million Authy end users, and a separate vishing incident on 29 June that exposed customer contact information was likely by the same actors (Confirmed [42]). Twilio then issued FIDO2 hardware tokens to all employees (Confirmed [42]). ATT&CK carries a 2022 Scattered Spider campaign against telecommunications and BPO companies (C0027); none of the primaries opened for Cloudflare, Twilio or Okta names Scattered Spider, so this study does not bind them to it (Confirmed for the data [124]; Inferred for the decision).

Uber. Uber says that on 15 September an attacker likely bought a contractor's corporate password after malware infected the contractor's personal device, then sent repeated two-factor approval requests until the contractor accepted one, and reached G-Suite, Slack, an invoice tool and the HackerOne dashboard (Confirmed [57]). Uber believes the attacker is affiliated with LAPSUS$; that is Uber's belief, not a finding (Confirmed [57]). Its response included password resets, key rotation, a code lock and a stronger MFA policy (Confirmed [57]).

What changed. CISA's October fact sheet on phishing-resistant MFA names phishing, push bombing, SS7 exploitation and SIM swap as threats to weaker MFA, and ranks FIDO/WebAuthn and PKI-based MFA as the gold standard (Confirmed [117]). Microsoft's DEV-0537 guidance says the same in operational terms: FIDO tokens or number matching, no telephony-based MFA, no location-based exclusions, alerts on admin role changes and transport rules, and out-of-band incident communications (Confirmed [23]).

Part 5: ransomware, extortion and the money

The year's advisories. AA22-040A of 9 February, from CISA, FBI and NSA with Australian and UK partners, described 2021's trends: RaaS use grew, actors used independent services to negotiate and arbitrate payments, and some offered victims 24/7 help centres (Confirmed [79]). Microsoft's 9 May profile of the RaaS economy separated operators, affiliates and access brokers, naming DEV-0193 (Trickbot LLC), ELBRUS (FIN7), DEV-0237, DEV-0401 (a LockBit 2.0 affiliate) and DEV-0537; in a six-month sample of 2,500 potential targets, 60 showed ransomware-linked activity, 20 were compromised and 1 had a ransomware event (Confirmed [80]). DEV-0193 and DEV-0237 are aliases of G0102 Wizard Spider in the library's data (Confirmed [124]). The joint advisories that followed:

Advisory	Date	Group	What it says	Source
AA22-152A	1 Jun	Karakurt	Leak site held several terabytes of purported victim data as of May; pressured victims by contacting employees, partners and clients; bought access from intrusion brokers	Confirmed [81]
AA22-181A	30 Jun	MedusaLocker	Observed as recently as May 2022; enters predominantly through RDP weaknesses; appears to run as RaaS	Confirmed [43]
AA22-187A	6 Jul	Maui (North Korea)	Healthcare and Public Health since at least May 2021	Confirmed [44]
AA22-223A	11 Aug	Zeppelin	2019 through at least June 2022 against defense contractors, education, manufacturing, technology and especially healthcare; demands from several thousand to over a million dollars in Bitcoin	Confirmed [51]
AA22-249A	6 Sep	Vice Society	Disproportionately targets education, especially K-12; changes account passwords to block remediation (FBI, CISA, MS-ISAC)	Confirmed [55]
AA22-257A	14 Sep	IRGC-affiliated actors	FortiOS and ProxyShell to data extortion and BitLocker encryption	Confirmed [56]
AA22-294A	21 Oct	Daixin Team	Healthcare and Public Health since at least June 2022; initial access through VPN servers (FBI, CISA, HHS)	Confirmed [66]
AA22-321A	17 Nov	Hive	Over 1,300 companies and about US$100 million in ransom from June 2021 through November 2022, per FBI; single-factor RDP and VPN, FortiOS CVE-2020-12812, phishing and ProxyShell (FBI, CISA, HHS)	Confirmed [69]
AA22-335A	1 Dec	Cuba	101 entities (65 in the US) as of August 2022; US$145 million demanded and US$60 million received; CVE-2022-24521 and ZeroLogon used; US entities doubled since the December 2021 FBI Flash	Confirmed [70]

S0625 Cuba has a library page; Karakurt, MedusaLocker, Maui, Zeppelin, Vice Society, Daixin and Hive have no ATT&CK object in the library's data (Confirmed [124]); the healthcare view of these groups is in the healthcare threat actor watchlist, and the ransomware business across 2019 to 2026, Conti, LockBit and Hive among it, is the subject of the ransomware ecosystem study.

Costa Rica and Conti. The State Department said on 6 May that in April Conti (S0575) carried out a ransomware incident against the Government of Costa Rica that disrupted its customs and tax platforms, offered up to US$10 million for information on Conti leaders, and cited FBI figures of over 1,000 Conti victims and payouts over US$150 million as of January 2022 (Confirmed [32]). Costa Rica's place in the ransomware record is told in the ransomware ecosystem study.

LockBit. AA23-165A, published in 2023, says LockBit was the most deployed ransomware variant worldwide in 2022: LockBit 3.0 (S1202) emerged in March 2022 and its builder leaked in September 2022; LockBit accounted for 22% of attributed Canadian incidents, 23% of CERT NZ reports and 16% of MS-ISAC SLTT incidents in 2022, and about 1,700 US attacks and roughly US$91 million in US ransoms since 2020 (Confirmed [82]).

State actors using ransomware. Maui, Prestige and the IRGC-affiliated BitLocker crew show state-linked actors using encryption, for money or as cover; their homes are Parts 2 and 3 (Confirmed [44][64][56] for the events; Inferred for the motive).

Arrests, sanctions and seizures. The FSB said on 14 January that, acting on a US request, the FSB and MVD searched 25 addresses of 14 REvil (S0496) members and seized over 426 million rubles including cryptocurrency, US$600,000, EUR 500,000, crypto wallets and 20 premium cars, with charges under Article 187 part 2 of the Russian Criminal Code, illegal circulation of means of payment (Confirmed [8]). The outcome of those cases is outside this record. On 5 April Treasury sanctioned Hydra, the world's largest darknet market, and the Garantex exchange; Germany's BKA shut Hydra's servers and seized about US$25 million in bitcoin; about US$8 million in ransomware proceeds from Ryuk (S0446), Sodinokibi and Conti transited Hydra; and Hydra's revenue rose from under US$10 million in 2016 to over US$1.3 billion in 2020 (Confirmed [28]). Australia later sanctioned Aleksandr Ermakov over the 2022 ransomware attack on Medibank and the exfiltration of data on 9.7 million users, and the US and UK designated him on 23 January 2024 in the first trilateral action of its kind (Confirmed [83]).

The money record. FinCEN reported on 1 November that ransomware-related Bank Secrecy Act filings for 2021 approached US$1.2 billion and that roughly 75% of ransomware incidents reported in the second half of 2021 involved Russia-related variants (Confirmed [84]). The FBI's IC3 2022 report counts 2,385 ransomware complaints with adjusted losses over US$34.3 million, 870 of them from critical infrastructure, where the top variants were LockBit (149), ALPHV/BlackCat (114; S1068) and Hive (87); it also counts 800,944 complaints in all, potential losses over US$10.2 billion, and business email compromise over US$2.7 billion (Confirmed [86]). IC3's ransomware losses come from complaints only and sit far below the payments in the advisories (Hive about US$100 million, Cuba US$60 million); the two figures measure different things (Inferred [86][69][70]).

International action. The second International Counter Ransomware Initiative summit met in Washington on 31 October and 1 November with 36 countries and the EU; members committed to disrupt actors, counter illicit finance and share information, set up an International Counter Ransomware Task Force, and Belgium joined (Confirmed [85]).

Other bridge thefts. Wormhole's own report says an attacker exploited a signature verification flaw in the Solana-side contract on 2 February to mint 120,000 unbacked wrapped ETH and bridged 93,750 back to Ethereum (Confirmed [10]). Harmony says multiple transactions compromised its Horizon Ethereum bridge from 05:30 PST on 23 June, and it moved the Ethereum side to a 4-of-5 multisig (Confirmed [40]). BNB Chain says the BSC Token Hub bridge was exploited in October through forging of a low-level proof that withdrew 2 million BNB; the exact day is not in the extract opened (Confirmed [61]). Dollar values for these thefts are the victims' or Treasury's values at the time, and token prices moved sharply during 2022 (Inferred).

Part 6: the exploited-vulnerability year

KEV in numbers. Computed from the KEV feed (catalog version 2026.11.10), 555 entries were added in 2022, 91 of them CVE-2022 ids; by month: January 40, February 32, March 226, April 45, May 83, June 48, July 3, August 23, September 24, October 12, November 10, December 9 (Confirmed [27]). The top vendors among 2022 additions were Microsoft (165), Adobe (54), Cisco (50) and Apple (26), and 132 of the year's additions are flagged for known ransomware use (Confirmed [27]). Of CVE-2022 ids in the catalog, 37 carry known ransomware campaign use as of that catalog version; the flag can change (Confirmed [27]). The March spike is backfill (Scope and method).

What was exploited most. AA23-215A says that in 2022 actors exploited older vulnerabilities more than new ones (Confirmed [87]). Its top 12 were FortiOS CVE-2018-13379, ProxyShell (CVE-2021-34473,

CVE-2021-31207, CVE-2021-34523), ManageEngine CVE-2021-40539, Confluence CVE-2021-26084, Log4Shell CVE-2021-44228 (of high interest through the first half of 2022), VMware CVE-2022-22954 and CVE-2022-22960, F5 CVE-2022-1388, Follina CVE-2022-30190 and Confluence CVE-2022-26134 (Confirmed [87]). AA22-117A, published on 27 April by seven Five Eyes agencies, had listed the 15 routinely exploited CVEs of 2021, led by Log4Shell, then ManageEngine CVE-2021-40539, the ProxyShell and ProxyLogon Exchange CVEs, Confluence CVE-2021-26084, vCenter CVE-2021-21972, ZeroLogon CVE-2020-1472, Exchange CVE-2020-0688, Pulse CVE-2019-11510 and FortiOS CVE-2018-13379 (Confirmed [88]). The 2021 record behind that list is in the 2021 chronicle.

The year's headline CVEs. In date order:

CVE	Product	What the record says	KEV added	Source
CVE-2022-0609	Chrome (Animation)	Use-after-free (CWE-416), fixed in 98.0.4758.102; exploited from 4 January by two North Korean groups	2022-02-15	Confirmed [89][3][27]
CVE-2022-22965	Spring Framework	RCE in Spring MVC and WebFlux on JDK 9+ deployed as WAR on a servlet container; leaked before the 31 March announcement; NVD CWE-94	2022-04-04	Confirmed [26][27]
CVE-2022-22954, CVE-2022-22960	VMware Workspace ONE Access and Identity Manager	Server-side template injection RCE, CVSSv3 9.8 (VMSA-2022-0011, 6 Apr); exploit built within 48 hours; ED 22-03 followed on 18 May for new CVE-2022-22972 and CVE-2022-22973	2022-04-14, 2022-04-15	Confirmed [90][29][30][27]
CVE-2022-1388	F5 BIG-IP iControl REST	Authentication bypass, NVD CWE-306, published 5 May; known ransomware use	2022-05-10	Confirmed [91][27]
CVE-2022-30190	Windows MSDT (Follina)	RCE when MSDT is called through the URL protocol from an application such as Word; NVD published 1 Jun with NVD-CWE-noinfo; known ransomware use	2022-06-14	Confirmed [37][27]
CVE-2022-26134	Confluence Server and Data Center	Critical unauthenticated OGNL injection RCE (NVD CWE-917), credited to Volexity; Cloud not vulnerable; AA23-215A says likely exploited as a zero-day	2022-06-02	Confirmed [38][115][87]
CVE-2022-27925 (with CVE-2022-37042), CVE-2022-24682, CVE-2022-27924, CVE-2022-30333	Zimbra Collaboration Suite	Exploited, per AA22-228A of 16 Aug	CVE-2022-27925: 2022-08-11	Confirmed [52][27]

CVE	Product	What the record says	KEV added	Source
CVE-2022-41040, CVE-2022-41082	Exchange Server	SSRF (CWE-918) and RCE (CWE-502) chained in August against fewer than 10 organizations; Chopper web shell; patched 8 Nov	2022-09-30	Confirmed [59][27]
CVE-2022-40684	FortiOS, FortiProxy, FortiSwitchManager	Authentication bypass by alternate path (Fortinet CWE-288; NVD CWE-287), CVSS 9.8; exploitation seen, including configuration download and rogue super_admin creation; known ransomware use	2022-10-11	Confirmed [62][115][27]
CVE-2022-3602, CVE-2022-3786	OpenSSL 3.0.0 to 3.0.6	X.509 buffer overrun fixed in 3.0.7; pre-announced as Critical, released as High; no known working RCE exploit; neither in KEV	n/a	Confirmed [67]
CVE-2022-42475	FortiOS SSL-VPN	Heap-based buffer overflow (Fortinet CWE-122; NVD CWE-197 and CWE-787), exploited in the wild; known ransomware use	2022-12-13	Confirmed [71][115][27]
CVE-2022-27518	Citrix ADC and Gateway as SAML SP or IdP	Unauthenticated RCE; limited targeted attacks in the wild	2022-12-13	Confirmed [72][93][27]

Other KEV additions of the year include Zimbra CVE-2022-41352 (20 October, known ransomware use), WSO2 CVE-2022-29464 (25 April, known ransomware use), WebRTC CVE-2022-2294 (25 August, known ransomware use), Linux Dirty Pipe CVE-2022-0847 (25 April) and Sophos Firewall CVE-2022-1040 (31 March) (Confirmed [27]). Nine CVE-2022 Chromium or WebRTC ids were added to KEV during 2022 (0609, 1096, 1364, 2856, 2294, 3075, 3723, 4135, 4262); CVE-2022-3038 followed on 30 March 2023 (Confirmed [89][27]). In December CrowdStrike reported that Play ransomware intrusions entered Exchange through OWASSRF, chaining CVE-2022-41080 with CVE-2022-41082 through OWA and bypassing the ProxyNotShell mitigations; CVE-2022-41080 entered KEV on 10 January 2023 (Confirmed [92]). The library has the Play group (G1040) and its ransomware (S1162 Playcrypt); the binding is this study's (Inferred [124]).

What the weaknesses say. The 2022 CWE Top 25 was built from NVD data for 2020 and 2021 (37,899 CVE records, final snapshot 13 June 2022), with CWE-787, CWE-79 and CWE-89 at the top (Confirmed [116]). A separate KEV-only ranking of 270 CVEs put CWE-787, CWE-78, CWE-416, CWE-20 and CWE-22 at the top, placed CWE-79 at 30 instead of 2, and found 20 percent of KEV records mapped to NVD-CWE-noinfo (Confirmed [116]). The weaknesses behind 2022's edge and server exploitation were mostly injection, deserialization and missing or broken authentication (CWE-917, CWE-502, CWE-918, CWE-306, CWE-287 and CWE-288), not the memory-safety classes at the top of the general list (Inferred [116][115]).

Log4Shell's second year. The home is the Log4Shell study. In short: AA22-174A of 23 June, from CISA and the US Coast Guard, said actors continued to exploit Log4Shell in VMware Horizon and Unified Access Gateway servers, and that systems not promptly updated after December 2021 should be treated as compromised (Confirmed [41]). AA22-320A of 16 November described a federal civilian agency compromised

as early as February 2022 by Iranian government-sponsored actors through Log4Shell in an unpatched VMware Horizon server; CISA found it through retrospective EINSTEIN analysis in April and was on site from mid-June to mid-July; the actors ran XMRig, used PsExec (S0029), Mimikatz (S0002) and ngrok (S0508), created a rogue domain admin, and were stopped by antivirus when they tried to dump LSASS (Confirmed [68]). The Cyber Safety Review Board's first report, on 11 July, called Log4j an endemic vulnerability that will remain in systems for many years, perhaps a decade or longer, made 19 recommendations in four categories, knew of no significant Log4j-based attacks on critical infrastructure, and found exploitation lower than many experts predicted while noting that many organizations do not collect the data and reporting is largely voluntary (Confirmed [106]).

Part 7: supply chain, cloud and data exposure

Humanitarian data. The ICRC says attackers entered its servers on 9 November 2021 through unpatched ManageEngine ADSelfService Plus CVE-2021-40539, that it determined the compromise on 18 January 2022, and that personal data of more than 515,000 people, including missing persons, their families and detainees, were affected (Confirmed [1]). The same CVE sits in AA23-215A's top 12 for 2022 (Confirmed [87]).

OAuth tokens and source code. Heroku says that on 7 April an actor used a compromised machine-account token to download customers' GitHub integration OAuth tokens and Review Apps and CI configuration variables, that hashed customer passwords were also exfiltrated, and that the investigation concluded on 30 May (Confirmed [96]). GitHub detected on 12 April that stolen OAuth user tokens issued to Heroku and Travis CI were used to download private repositories, including npm's, and that an AWS API key was then used against npm infrastructure; its alert was published on 15 April and finalized on 27 April (Confirmed [95]). On 27 December stolen Slack employee tokens were used to download private GitHub repositories, with no customer data involved, per Slack's notice of 31 December (Confirmed [98]).

LastPass. LastPass disclosed on 25 August a development-environment intrusion through one compromised developer account, with source code taken and no customer data accessed (Confirmed [54]). Its 22 December update says the actor used information from the August incident to target another employee, then reached third-party cloud storage and copied backup account data and a backup of customer vault data, with sensitive fields encrypted by the master password and URLs not encrypted (Confirmed [54]).

Package registries. PyTorch says a dependency-confusion package, torchtriton, on PyPI was pulled by Linux nightly pip installs from 25 to 30 December, and its binary uploaded system information, SSH files and home-directory files over DNS (Confirmed [97]). The home for registry attacks is the npm supply chain study, and for machine-learning supply chains the Hugging Face study.

Cloud exposure and scraping. Microsoft's MSRC said on 19 October that a misconfigured, unused endpoint allowed unauthenticated access to prospective-customer business transaction data, that SOCRadar reported it on 24 September, and that SOCRadar overstated the scope (Confirmed [99]). Twitter said on 5 August that a June 2021 code change let an email address or phone number be matched to an account, that the flaw was reported through its bug bounty in January 2022 and fixed, and that in July 2022 it learned through a press report that the compiled data was offered for sale (Confirmed [47]).

Australia's two breaches. Optus said on 22 September that a cyberattack exposed customer names, dates of birth, phone numbers and emails, and for a subset addresses and identity document numbers, but not payment details or passwords (Confirmed [100]). The Australian Information Commissioner alleges that from

about 17 October 2019 to 20 September 2022 Optus interfered with the privacy of about 9.5 million Australians (Confirmed [58]). For Medibank, the OAIC filed civil penalty proceedings on 5 June 2024 over the October 2022 breach, alleging that from March 2021 to October 2022 Medibank failed to protect the personal information of 9.7 million Australians (Confirmed [65]).

Regulators and executives. On 24 October the FTC acted against Drizly and its CEO personally over security failures that exposed data on about 2.5 million consumers; the breach followed credentials stored on GitHub, and the order follows the CEO to future companies (Confirmed [101]).

Part 8: industrial and critical infrastructure

The home for the Ukrainian grid attacks is the Sandworm study; for the earlier ICS record see the Stuxnet study, and for the years that followed the ICS attacks and advisories study, 2024 to 2026.

Tools built for PLCs. AA22-103A of 13 April, from DOE, CISA, NSA and the FBI (revised 25 May), describes custom tools to scan, compromise and control Schneider Electric MODICON and MODICON Nano PLCs, OMRON Sysmac NJ/NX PLCs and OPC UA servers, plus an exploit for ASRock driver CVE-2020-15368 (Confirmed [33]). It references Mandiant's INCONTROLLER and Dragos's PIPEDREAM but does not name the tools itself, and it maps 39 ATT&CK for ICS ids from T0801 to T0889 (Confirmed [33]). INCONTROLLER is S1045 in the library's ICS data but has no generated page, so it is not linked (Confirmed [124]).

The grid, twice. Industroyer2 was set to run on 8 April and, per the library's ATT&CK page, was found before it caused impact (Part 2; Confirmed [31] for the schedule, Reported [131] for no impact). Sandworm's October attack used the utility's own MicroSCADA tooling to cause an outage during mass missile strikes (Part 2; Confirmed [63]). Between the two, the technique moved from purpose-built malware that speaks IEC-104 to a native binary already on the SCADA server (Inferred [31][63]).

A satellite network as infrastructure. KA-SAT was not an industrial control system, but its attack disrupted wind farms in central Europe (Confirmed [6]). The lesson is the management plane: the attacker needed only access to the segment that manages devices (Confirmed [19]; Inferred for the lesson).

History in the indictments. AA22-083A of 24 March documented TRITON at a Middle East refinery in 2017 alongside the FSB energy campaigns (Confirmed [25]). ATT&CK records that operation as C0030, the Triton Safety Instrumented System Attack, by TEMP.Veles (Confirmed [124]); Triton (S1009) is in the library's ICS data without a generated page (Confirmed [124]).

The policy response. AA22-110A told critical infrastructure owners to patch KEV entries, require MFA, restrict RDP, segment IT from OT and keep immutable backups (Confirmed [35]). The President's statement of 21 March urged them to harden immediately (Confirmed [105]). CISA published its Cross-Sector Cybersecurity Performance Goals in a 2022 edition; the release day commonly given as 27 October was not confirmed from an opened page (Confirmed [111]).

Part 9: the government record

Reporting and disclosure. CIRCIA was enacted on 15 March as Division Y of the Consolidated Appropriations Act, 2022 (PL 117-103, H.R. 2471) (Confirmed [102]). Once CISA's final rule takes effect it requires covered incidents to be reported within 72 hours and ransom payments within 24 hours; the proposed rule was published on 4 April 2024 and the final rule is still in progress (Confirmed [103]). The SEC proposed cybersecurity incident-reporting and risk-governance disclosure rules for public companies on 9 March (Confirmed [104]).

Directives and federal policy. ED 22-03 of 18 May ordered agencies to act on VMware CVE-2022-22972 and CVE-2022-22973 after the April flaws were exploited within 48 hours (Confirmed [29]). OMB M-22-18 of 14 September requires agencies to comply with NIST's SSDF (SP 800-218) and the NIST software supply chain guidance when they use software, implementing Executive Order 14028 (Confirmed [107]). BOD 23-01 of 3 October requires federal agencies to run asset discovery every 7 days and vulnerability enumeration every 14 days, by 3 April 2023 (Confirmed [109]). Executive Order 14086, signed 7 October, set safeguards for US signals intelligence activities and created the Data Protection Review Court (Confirmed [110]). The Quantum Computing Cybersecurity Preparedness Act became Public Law 117-260 on 21 December, encouraging federal migration to quantum-resistant cryptography (Confirmed [113]).

Europe and the UK. The European Commission proposed the Cyber Resilience Act on 15 September, with mandatory cybersecurity requirements for products with digital elements across their lifecycle (Confirmed [108]). The Commission says NIS2 came into force in January 2023 with transposition due by 17 October 2024; its December 2022 adoption date was not confirmed because EUR-Lex returned nothing (Confirmed [114]). The UK Product Security and Telecommunications Infrastructure Act 2022, on the security of internet-connectable products, was enacted on 6 December (Confirmed [112]).

Attribution, indictments and sanctions. In 2022 governments attributed the January defacements and WhisperGate to Russian military intelligence and the Viasat attack to Russia (10 May) [5][6]; the Ronin theft to Lazarus Group (Treasury, 6 May) [24]; and the Albania attack to Iranian state actors, with OFAC naming the MOIS (September) [46][76] (all Confirmed). DOJ unsealed charges against three FSB officers and a TsNIIKhM employee on 24 March (Confirmed [25]). Treasury sanctioned Hydra and Garantex, then Blender.io, then Tornado Cash, then the MOIS and an IRGC-affiliated ransomware crew (Confirmed [28][24][49][76][77]). The FTC held a CEO personally to a security order (Confirmed [101]). The International Counter Ransomware Initiative set up its task force (Confirmed [85]).

The ATT&CK framework itself. ATT&CK v12, released on 25 October, added the Campaign object with 14 Enterprise campaigns, added detections to ATT&CK for ICS, and renamed Indicator Removal on Host to Indicator Removal (T1070) (Confirmed [120]). The campaigns this study binds (C0017, C0034, C0038) are objects of that kind (Confirmed [124]).

Part 10: the defender view

Patch the KEV list first, and treat late patching as compromise. AA22-110A and the Hive, Cuba and Vice Society advisories put KEV-first patching at the top, and the Log4Shell advisories on VMware Horizon go further: systems not updated after December 2021 should be treated as compromised (Confirmed [35][69][70][55][41][68]). AA22-117A's controls are to patch known exploited and internet-facing flaws first, require MFA for all users and on all VPNs, review privileged accounts every year, restrict native scripting tools, segment the network, run EDR and SIEM, and use application allowlisting (Confirmed [88]). AA22-279A adds: use phishing-resistant MFA, block obsolete protocols at the edge, replace end-of-life devices, move toward Zero Trust and keep robust logs on internet-facing systems (Confirmed [60]).

MFA quality, not MFA presence. The year's identity failures were fail-open MFA (AA22-074A), push fatigue (DEV-0537, Uber) and SMS phishing that harvested credentials (Twilio, Cloudflare); the control that held was FIDO2 (Cloudflare) (Confirmed [22][23][57][42][48]). Review MFA for fail-open settings, dormant enrolments and help-desk reset paths (Confirmed [118][23]; Inferred for the combination).

Trust relationships. AA22-131A asks MSPs and their customers to keep logs for six months, put MFA on all MSP accounts and review it for fail-open settings, stop reusing admin credentials across customers, apply least privilege and write security ownership into contracts (Confirmed [118]). Okta's support engineer, Uber's contractor and KA-SAT's management segment are the same problem at different scales (Confirmed [9][57][19]; Inferred for the comparison).

Ransomware readiness. The Hive, Cuba and Vice Society advisories repeat the same controls: offline, encrypted, immutable and tested backups; phishing-resistant MFA for webmail, VPN and backup-admin accounts; KEV-first patching; restricting exposed RDP; segmentation; EDR; PowerShell logging; and removing SMBv1 (Confirmed [69][70][55]). AA22-057A adds staged patch and signature rollout, verifying update integrity, and keeping offline installation media and backups for the wiper case (Confirmed [17]).

Hunting cues from the record. At the advisory level, and without commands. Each cue is this study's reading of a behavior the sources describe (behaviors Confirmed; cues Inferred):

- Edge and appliance exposure: management interfaces of firewalls and VPNs reachable from the internet (Cyclops Blink, FortiOS CVE-2022-40684) and VPN appliances that reach a management segment (KA-SAT) (Confirmed [13][62][19]).
- Identity signals: bursts of MFA prompts to one user, new MFA device enrolment on a dormant account, new global admins, new mail transport rules, and help-desk reset requests (Confirmed [23][22][57]).
- Post-exploitation signals: web shells on Exchange (Chopper), rogue domain admins, cryptominers and tunnelling tools such as ngrok on servers that should not run them (Confirmed [59][68]).
- Developer estate signals: OAuth token use from unusual locations, bulk repository downloads, and access to cloud storage holding backups (Confirmed [95][96][54]).
- OT signals: native SCADA binaries issuing commands outside change windows (Confirmed [63]; Inferred for the cue).

Exposure management. BOD 23-01's seven-day discovery and 14-day enumeration cadence is a usable baseline for any organization's asset inventory (Confirmed [109]; Inferred for the generalization). See the library's Vulnerability Prioritization Reference and Edge Device Security Reference.

Part 11: MITRE mappings

This Part binds the verified 2022 record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/weaknesses/cwe.jsonl`, and the group, software and campaign files) and the generated pages under `mitre/` on 11 November 2026 (Demonstrated [122][123][124][125][126][127]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment; on the live site T1685 Disable or Modify Tools sits under Defense Impairment (TA0112), created 14 April 2026 (Confirmed [121]).

Each row carries a basis. **Source** means an opened advisory, vendor report or ATT&CK page prints the ATT&CK id itself. **Behavior** means the source describes the behavior and this study assigns the id (the behavior is Confirmed; the mapping is this study's reading). The advisories' v10 and v11 ids were resolved against v20.0: every Enterprise id in AA22-320A, AA22-321A, AA22-335A, AA22-249A, AA22-277A and AA22-074A resolves except T1562 and T1562.001 (revoked into T1685 Disable or Modify Tools) and T1574.002 (revoked into T1574.001 DLL), and T1036.005 is now named Match Legitimate Resource Name or Location (Demonstrated [122]). T1562.004 in AA22-054A maps to T1686 and T1562.009 in AA22-181A maps to T1688 (Demonstrated [122]).

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1591.002	Gather Victim Org Information: Business Relationships	Reconnaissance	AA22-152A table (Karakurt pressured employees, partners and clients, 1 Jun)	Source	[81]
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance	AA22-158A table (PRC actors against network devices, 7 Jun)	Source	[39]
T1598.002	Phishing for Information: Spearphishing Attachment	Reconnaissance	AA22-294A table (Daixin Team, 21 Oct)	Source	[66]
T1598.003	Phishing for Information: Spearphishing Link	Reconnaissance	SMS phishing to fake Okta login pages at Cloudflare (20 Jul) and Twilio (Aug)	Behavior	[48][42]
T1598.004	Phishing for Information: Spearphishing Voice	Reconnaissance	Vishing incident at Twilio (29 Jun); help-desk social engineering by DEV-0537 (Mar)	Behavior	[42][23]
T1583.001	Acquire Infrastructure: Domains	Resource Development	Lookalike Okta domain in the Cloudflare SMS phishing wave (20 Jul)	Behavior	[48]
T1584.001	Compromise Infrastructure: Domains	Resource Development	AA22-335A table (Cuba ransomware, 1 Dec)	Source	[70]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA22-011A, AA22-158A, AA22-152A, AA22-249A, AA22-294A, AA22-335A, AA22-074A and AA22-277A tables; a contractor's bought password at Uber (Sep)	Source	[74][39][81][55][66][70][22][2][57]
T1078.001	Valid Accounts: Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA22-320A table (federal agency, Feb to Jul)	Source	[68]
T1133	External Remote Services	Persistence, Initial Access	AA22-054A, AA22-158A, AA22-152A, AA22-181A, AA22-321A, AA22-335A and AA22-074A tables; misconfigured VPN appliance at KA-SAT (24 Feb); Cisco VPN access (May)	Source	[13][39][81][43][69][70][22][19][50]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1190	Exploit Public-Facing Application	Initial Access	AA22-011A, AA22-320A, AA22-158A, AA22-152A, AA22-249A, AA22-294A, AA22-321A and AA22-335A tables; behavior at the ICRC (ManageEngine, Nov 2021), APT41 (USAHerds and Log4j), Albania (SharePoint), Confluence (Jun), Exchange (Aug), FortiOS (Oct, Dec) and Citrix (Dec)	Source	[74][68][39][81][55][66][69][70][1][21][46][38][59][62][71][72]
T1195.001	Supply Chain Compromise: Compromise Software Dependencies and Development Tools	Initial Access	torchtriton dependency-confusion package on PyPI (25 to 30 Dec)	Behavior	[97]
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Initial Access	AA22-011A table (Russian state-sponsored actors, 11 Jan)	Source	[74]
T1199	Trusted Relationship	Initial Access	Okta tenants reached through a Sitel support engineer's workstation (21 Jan); AA22-131A on MSP trust relationships (11 May); listed for LAPSUS$ in the library's G1004 data	Behavior	[9][118][125]
T1566	Phishing	Initial Access	AA22-181A and AA22-335A tables	Source	[43][70]
T1566.001	Phishing: Spearphishing Attachment	Initial Access	AA22-152A and AA22-321A tables	Source	[81][69]
T1047	Windows Management Instrumentation	Execution	AA22-249A and AA22-277A tables	Source	[55][2]
T1053	Scheduled Task/Job	Execution, Persistence, Privilege Escalation	AA22-249A table (Vice Society, 6 Sep)	Source	[55]
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	AA22-320A table; ATT&CK campaign C0034	Source	[68][119]
T1059	Command and Scripting Interpreter	Execution	AA22-321A table (Hive); Mandiant's report on the October Sandworm OT attack	Source	[69][63]
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	AA22-320A, AA22-181A and AA22-335A tables; ATT&CK campaign C0034	Source	[68][43][70][119]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1059.004	Command and Scripting Interpreter: Unix Shell	Execution	AA22-054A table (Cyclops Blink, 23 Feb)	Source	[13]
T1059.006	Command and Scripting Interpreter: Python	Execution	AA22-277A table (Defense Industrial Base intrusion)	Source	[2]
T1059.008	Command and Scripting Interpreter: Network Device CLI	Execution	AA22-187A table (Maui ransomware, 6 Jul)	Source	[44]
T1072	Software Deployment Tools	Execution, Lateral Movement	AA22-335A table	Source	[70]
T1129	Shared Modules	Execution	AA22-054A table	Source	[13]
T1203	Exploitation for Client Execution	Execution	Chrome CVE-2022-0609 exploited by two North Korean groups (4 Jan to 14 Feb)	Behavior	[3][89]
T1204.002	User Execution: Malicious File	Execution	Trojanized cryptocurrency applications installed by blockchain-company staff (TraderTraitor, AA22-108A)	Behavior	[34]
T1574.001	Hijack Execution Flow: DLL	Stealth, Execution	AA22-249A table printed T1574.002, revoked into T1574.001 in v20	Source	[55][122]
T1037.004	Boot or Logon Initialization Scripts: RC Scripts	Persistence, Privilege Escalation	AA22-054A table	Source	[13]
T1098	Account Manipulation	Persistence, Privilege Escalation	AA22-320A and AA22-294A tables	Source	[68][66]
T1098.003	Account Manipulation: Additional Cloud Roles	Persistence, Privilege Escalation	DEV-0537 created global admins in victims' cloud tenants (Mar)	Behavior	[23]
T1112	Modify Registry	Defense Impairment, Persistence	AA22-074A and AA22-321A tables	Source	[22][69]
T1136.001	Create Account: Local Account	Persistence	AA22-320A table	Source	[68]
T1136.002	Create Account: Domain Account	Persistence	AA22-320A table (rogue domain admin account)	Source	[68]
T1505.003	Server Software Component: Web Shell	Persistence	ATT&CK campaign C0034; Chopper web shell installed through the Exchange flaws (Aug)	Source	[119][59]
T1542.001	Pre-OS Boot: System Firmware	Stealth, Persistence	AA22-054A table (fake firmware update)	Source	[13]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1543.002	Create or Modify System Process: Systemd Service	Persistence, Privilege Escalation	ATT&CK campaign C0034	Source	[119]
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	AA22-249A table	Source	[55]
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	AA22-249A table	Source	[55]
T1556	Modify Authentication Process	Defense Impairment, Persistence, Credential Access	AA22-074A table (MFA made to fail open)	Source	[22]
T1556.007	Modify Authentication Process: Hybrid Identity	Defense Impairment, Persistence, Credential Access	MagicWeb on AD FS servers (NOBELIUM, disclosed 24 Aug)	Behavior	[53]
T1055	Process Injection	Stealth, Privilege Escalation	AA22-249A table	Source	[55]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	AA22-249A, AA22-335A and AA22-074A tables (PrintNightmare, CVE-2022-24521)	Source	[55][70][22]
T1484.001	Domain or Tenant Policy Modification: Group Policy Modification	Defense Impairment, Privilege Escalation	ATT&CK campaign C0034	Source	[119]
T1036	Masquerading	Stealth	AA22-249A table	Source	[55]
T1036.004	Masquerading: Masquerade Task or Service	Stealth	ATT&CK campaign C0034	Source	[119]
T1036.005	Masquerading: Match Legitimate Resource Name or Location	Stealth	AA22-054A table (the id is now named Match Legitimate Resource Name or Location)	Source	[13][122]
T1070	Indicator Removal	Stealth	AA22-321A table (named Indicator Removal since ATT&CK v12)	Source	[69][120]
T1070.004	Indicator Removal: File Deletion	Stealth	AA22-320A table	Source	[68]
T1218	System Binary Proxy Execution	Stealth	Mandiant's report on the October Sandworm OT attack	Source	[63]
T1480	Execution Guardrails	Stealth	Mandiant's APT41 report (8 Mar)	Source	[21]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1497	Virtualization/Sandbox Evasion	Stealth, Discovery	AA22-249A table	Source	[55]
T1553.002	Subvert Trust Controls: Code Signing	Defense Impairment	HermeticWiper signed with a certificate issued to Hermetica Digital Ltd (23 Feb)	Behavior	[16]
T1599	Network Boundary Bridging	Defense Impairment	AA22-158A table	Source	[39]
T1685	Disable or Modify Tools	Defense Impairment	Printed as T1562.001 in AA22-320A, AA22-055A and AA22-335A and as T1562 in AA22-321A; both revoked into T1685 in v20	Source	[68][20][70][69][122]
T1686	Disable or Modify System Firewall	Defense Impairment	Printed as T1562.004 in AA22-054A; revoked into T1686 in v20	Source	[13][122]
T1688	Safe Mode Boot	Defense Impairment	Printed as T1562.009 in AA22-181A (MedusaLocker); revoked into T1688 in v20	Source	[43][122]
T1003	OS Credential Dumping	Credential Access	AA22-294A table	Source	[66]
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	AA22-320A and AA22-335A tables	Source	[68][70]
T1003.003	OS Credential Dumping: NTDS	Credential Access	AA22-011A and AA22-074A tables	Source	[74][22]
T1110.001	Brute Force: Password Guessing	Credential Access	AA22-074A table (dormant NGO account)	Source	[22]
T1110.003	Brute Force: Password Spraying	Credential Access	AA22-011A table	Source	[74]
T1528	Steal Application Access Token	Credential Access	Compromised token used to download customers' GitHub integration OAuth tokens at Heroku (7 Apr)	Behavior	[96]
T1552.001	Unsecured Credentials: Credentials In Files	Credential Access	Drizly breach followed credentials stored on GitHub (FTC, 24 Oct)	Behavior	[101]
T1555	Credentials from Password Stores	Credential Access	AA22-320A and AA22-158A tables	Source	[68][39]
T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting	Credential Access	AA22-011A and AA22-335A tables	Source	[74][70]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1621	Multi-Factor Authentication Request Generation	Credential Access	Repeated MFA prompts by DEV-0537 (Mar) and at Uber (Sep); listed for LAPSUS$ in the library's G1004 data	Behavior	[23][57][125]
T1016.001	System Network Configuration Discovery: Internet Connection Discovery	Discovery	AA22-320A and AA22-158A tables	Source	[68][39]
T1018	Remote System Discovery	Discovery	AA22-320A and AA22-074A tables	Source	[68][22]
T1082	System Information Discovery	Discovery	AA22-054A table	Source	[13]
T1021.001	Remote Services: Remote Desktop Protocol	Lateral Movement	AA22-320A table	Source	[68]
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	AA22-277A table	Source	[2]
T1080	Taint Shared Content	Lateral Movement	AA22-249A table	Source	[55]
T1550.001	Use Alternate Authentication Material: Application Access Token	Lateral Movement	Stolen OAuth user tokens issued to Heroku and Travis CI used to download private repositories (detected 12 Apr)	Behavior	[95]
T1550.002	Use Alternate Authentication Material: Pass the Hash	Lateral Movement	AA22-294A table	Source	[66]
T1550.004	Use Alternate Authentication Material: Web Session Cookie	Lateral Movement	Bought session tokens replayed by DEV-0537 (Mar)	Behavior	[23]
T1563.001	Remote Service Session Hijacking: SSH Hijacking	Lateral Movement	AA22-294A table	Source	[66]
T1563.002	Remote Service Session Hijacking: RDP Hijacking	Lateral Movement	AA22-294A and AA22-335A tables	Source	[66][70]
T1570	Lateral Tool Transfer	Lateral Movement	ATT&CK campaign C0034	Source	[119]
T1074.002	Data Staged: Remote Data Staging	Collection	AA22-277A table	Source	[2]
T1114.002	Email Collection: Remote Email Collection	Collection	Email exfiltrated from Albanian government networks before the July attack (AA22-264A)	Behavior	[46]
T1114.003	Email Collection: Email Forwarding Rule	Collection	DEV-0537 set mail transport rules to forward mail (Mar)	Behavior	[23]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1119	Automated Collection	Collection	AA22-158A table	Source	[39]
T1213.003	Data from Information Repositories: Code Repositories	Collection	Private repositories downloaded at GitHub and npm (Apr) and Slack (27 Dec); LastPass source code taken (Aug)	Behavior	[95][98][54]
T1530	Data from Cloud Storage	Collection	Backup of LastPass customer vault data copied from third-party cloud storage (update of 22 Dec)	Behavior	[54]
T1560.001	Archive Collected Data: Archive via Utility	Collection	AA22-074A and AA22-277A tables	Source	[22][2]
T1008	Fallback Channels	Command and Control	AA22-054A table	Source	[13]
T1071.001	Application Layer Protocol: Web Protocols	Command and Control	AA22-054A table	Source	[13]
T1090	Proxy	Command and Control	AA22-054A, AA22-320A and AA22-335A tables (ngrok in AA22-320A)	Source	[13][68][70]
T1090.003	Proxy: Multi-hop Proxy	Command and Control	AA22-011A table	Source	[74]
T1095	Non-Application Layer Protocol	Command and Control	ATT&CK campaign C0034	Source	[119]
T1102.001	Web Service: Dead Drop Resolver	Command and Control	Mandiant's APT41 report (8 Mar)	Source	[21]
T1105	Ingress Tool Transfer	Command and Control	AA22-320A table	Source	[68]
T1132.002	Data Encoding: Non-Standard Encoding	Command and Control	AA22-054A table	Source	[13]
T1219	Remote Access Tools	Command and Control	AA22-152A table	Source	[81]
T1571	Non-Standard Port	Command and Control	AA22-054A table	Source	[13]
T1572	Protocol Tunneling	Command and Control	AA22-158A table; ATT&CK campaign C0034	Source	[39][119]
T1573.002	Encrypted Channel: Asymmetric Cryptography	Command and Control	AA22-054A table	Source	[13]
T1020.001	Automated Exfiltration: Traffic Duplication	Exfiltration	AA22-158A table (traffic mirroring at telecom providers)	Source	[39]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1029	Scheduled Transfer	Exfiltration	AA22-277A table	Source	[2]
T1041	Exfiltration Over C2 Channel	Exfiltration	AA22-054A table	Source	[13]
T1048	Exfiltration Over Alternative Protocol	Exfiltration	AA22-152A table	Source	[81]
T1537	Transfer Data to Cloud Account	Exfiltration	AA22-321A table	Source	[69]
T1567	Exfiltration Over Web Service	Exfiltration	AA22-294A table	Source	[66]
T1567.002	Exfiltration Over Web Service: Exfiltration to Cloud Storage	Exfiltration	AA22-152A and AA22-277A tables (OneDrive in AA22-277A)	Source	[81][2]
T1485	Data Destruction	Impact	ATT&CK campaign C0034; wipers deployed against Ukraine since January (AA22-057A, ESET)	Source	[119][17][16]
T1486	Data Encrypted for Impact	Impact	AA22-187A, AA22-181A, AA22-249A, AA22-294A and AA22-321A tables; Prestige (11 Oct); the Albania encryptor (Jul); IRGC-affiliated BitLocker abuse	Source	[44][43][55][66][69][64][46][56]
T1490	Inhibit System Recovery	Impact	AA22-181A and AA22-321A tables	Source	[43][69]
T1491.002	Defacement: External Defacement	Impact	Defacements of Ukrainian government websites (13 Jan)	Behavior	[5]
T1495	Firmware Corruption	Impact	Legitimate management commands overwrote KA-SAT modem flash (24 Feb)	Behavior	[19]
T1496.001	Resource Hijacking: Compute Hijacking	Impact	XMRig cryptocurrency miner on the federal agency's network (AA22-320A)	Behavior	[68]
T1498	Network Denial of Service	Impact	DDoS against Ukrainian websites before HermeticWiper (23 Feb); claimed Killnet DDoS on a US airport (AA22-110A)	Behavior	[16][35]
T1531	Account Access Removal	Impact	AA22-249A table; DEV-0537 removed other admins (Mar)	Source	[55][23]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1561.002	Disk Wipe: Disk Structure Wipe	Impact	WhisperGate overwrites the MBR (13 Jan); ZeroCleare-version wiper with the RawDisk driver in Albania (Jul)	Behavior	[4][46]
T1657	Financial Theft	Impact	Bridge thefts: Wormhole (2 Feb), Ronin, attributed to Lazarus Group by Treasury (23 Mar), Harmony (23 to 24 Jun) and BNB Chain (Oct)	Behavior	[10][24][40][61]

Ids the record mentions but this study leaves out: the remaining rows of AA22-055A's and AA22-277A's tables (35 rows in AA22-277A) are not listed individually in the verified record, so only the ids named above are bound (Confirmed [20][2]). T1111 Multi-Factor Authentication Interception is in the library's G1004 record, but no opened 2022 primary in this study describes code interception in a specific intrusion, so it is left out (Demonstrated [125]; Inferred for the decision). The library's G1004 record carries 43 techniques, including T1621, T1111, T1199, T1598.004, T1684.001 Impersonation, T1114.003, T1531 and T1098.003 (Demonstrated [125]).

ATT&CK for ICS techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T0847	Replication Through Removable Media	Initial Access	Mandiant's report on the October Sandworm OT attack	Source	[63]
T0871	Execution through API	Execution	Mandiant's report on the October Sandworm OT attack	Source	[63]
T0895	Autorun Image	Execution	ATT&CK campaign C0034	Source	[119]
T1701.002	Command and Scripting Interpreter: Windows Command Shell	Execution	ATT&CK campaign C0034	Source	[119]
T1701.004	Command and Scripting Interpreter: Visual Basic	Execution	ATT&CK campaign C0034	Source	[119]
T0889	Modify Program	Persistence	Last id in AA22-103A's table	Source	[33]
T1693.001	Modify Firmware: System Firmware	Persistence, Inhibit Response Function, Impair Process Control	AA22-103A printed T0857 System Firmware, revoked into T1693.001	Source	[33][122]
T1694.001	Insecure Credentials: Default Credentials	Persistence, Lateral Movement	AA22-103A printed T0812 Default Credentials, revoked into T1694.001	Source	[33][122]
T0872	Indicator Removal on Host	Evasion	Mandiant's report on the October Sandworm OT attack	Source	[63]
T0894	System Binary Proxy Execution	Evasion	ATT&CK campaign C0034	Source	[119]
T1692.001	Unauthorized Message: Command Message	Evasion, Impair Process Control	AA22-103A and Mandiant printed T0855 Unauthorized Command Message, revoked into T1692.001; listed for C0034; Industroyer2's IEC-104 commands (8 Apr) (Industroyer2 mapping is Behavior, this study's)	Source	[33][63][119][31][122]
T0801	Monitor Process State	Collection	First id in AA22-103A's table (39 ICS ids, T0801 to T0889)	Source	[33]
T0809	Data Destruction	Inhibit Response Function	Mandiant's report on the October Sandworm OT attack	Source	[63]
T1691.001	Block Operational Technology Message: Command Message	Inhibit Response Function	AA22-103A printed T0803 Block Command Message, revoked into T1691.001	Source	[33][122]

Id	Name	Tactic (v20.0)	Where it appears in the 2022 record	Basis	Source
T1691.002	Block Operational Technology Message: Reporting Message	Inhibit Response Function	AA22-103A printed T0804 Block Reporting Message, revoked into T1691.002	Source	[33][122]
T0831	Manipulation of Control	Impact	Mandiant's report on the October Sandworm OT attack	Source	[63]
T0837	Loss of Protection	Impact	AA22-103A table, which labels this id Loss of Safety; the library names it Loss of Protection	Source	[33][123]

AA22-103A maps 39 ICS ids; this study's verified record names only the ids above, so the rest of that table is not bound here (Confirmed [33]). Of the 39, 32 resolve directly in the library's ICS data; T0803, T0804, T0812, T0855 and T0857 map to newer ids as shown; T0807 Command-Line Interface and T0853 Scripting are deprecated with no recorded successor and stay out of the layer (Demonstrated [122]). The advisory labels T0837 "Loss of Safety", but in the library's data T0837 is Loss of Protection and Loss of Safety is T0880; the layer uses T0837 and flags the label (Demonstrated [123]). From Mandiant's report, ICS T0807 and T0853 are deprecated and T0855 maps to T1692.001 (Confirmed [63][122]). The library has no generated ATT&CK for ICS technique pages, so these ids are not linked (Demonstrated [124]).

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the 2022 record	Source
Sandworm Team	G0034	Cyclops Blink (23 Feb); Industroyer2 (8 Apr, ESET high confidence); C0034 (Jun to Oct); Prestige through the IRIDIUM and Seashell Blizzard aliases; GTsST Unit 74455 (AA22-110A)	[13][31][63][64][35][124]
Ember Bear	G1003	DEV-0586 and Cadet Blizzard aliases; WhisperGate (13 Jan)	[4][7][124]
APT28	G0007	STRONTIUM domains taken over (6 Apr); GTsSS Unit 26165	[75][35]
APT29	G0016	Named in AA22-011A; NOBELIUM alias; MagicWeb (24 Aug)	[74][53][124]
Dragonfly	G0035	Berserk Bear alias; assessed as almost certainly FSB Center 16 (AA22-110A); 2011 to 2018 energy campaign (AA22-083A)	[35][25][124]
TEMP.Veles	G0088	TRITON in 2017 (AA22-083A)	[25]
Triton Safety Instrumented System Attack	C0030	The 2017 refinery operation in AA22-083A (match of the ATT&CK campaign to the advisory is this study's)	[25][124]
Gamaredon Group	G0047	ACTINIUM alias; targeting of Ukraine since October 2021; not attributed by AA22-110A	[11][35]
Turla	G0010	Named in AA22-110A, not attributed by it	[35]
Wizard Spider	G0102	WIZARD SPIDER (Conti) in AA22-110A; DEV-0193 and DEV-0237 aliases in Microsoft's RaaS profile	[35][80][124]
LAPSUS$	G1004	DEV-0537 and Strawberry Tempest aliases; Microsoft profile (22 Mar); Uber's belief; Talos's broker tie	[23][57][50][125]
MuddyWater	G0069	AA22-055A (24 Feb), a subordinate element of the MOIS	[20]
OilRig	G0049	EUROPIUM alias; Microsoft links the Albania access to EUROPIUM with moderate confidence	[45][124]
VOID MANTICORE	G1055	"Homeland Justice" alias	[46][124]
HomeLand Justice	C0038	Albania, May 2021 to September 2022	[46][124]
Magic Hound	G0059	Charming Kitten and APT35 aliases; Treasury's IRGC designations (mapping Inferred)	[77][124]
Lazarus Group	G0032	Ronin (Treasury); Tornado Cash laundering; TraderTraitor; SDN update	[24][49][34][78]

Object	Id and library page	Tie to the 2022 record	Source
APT38	G0082	Bluenoroff and Stardust Chollima aliases; named in AA22-108A	[34][124]
AppleJeus	G1049	TAG's "Operation AppleJeus" group exploiting CVE-2022-0609 (alias match Inferred)	[3][124]
APT41	G0096	Six US state governments, May 2021 to February 2022	[21]
C0017	C0017	APT41 against US state governments	[21][124]
2022 Ukraine Electric Power Attack	C0034	June to October 2022	[63][119][129]
WhisperGate	S0689	MBR wiper, 13 Jan	[4][17]
HermeticWiper	S0697	23 Feb; aliases include DriveSlayer	[16][17][124]
HermeticWizard	S0698	AA22-057A update	[17]
CaddyWiper	S0693	With Industroyer2 (8 Apr); new variant (12 Oct)	[17][31][63]
Industroyer2	S1072	IEC-104 only, 8 Apr	[31]
Cyclops Blink	S0687	WatchGuard devices, since at least June 2019	[13]
VPNFilter	S1010	Replaced by Cyclops Blink	[13][14]
AcidRain	S1125	Tied to KA-SAT by the library's ATT&CK page; primary not opened	[128]
Prestige	S1058	Ukraine and Poland, 11 Oct	[64]
ZeroCleare	S1151	Albania wiper	[45][46]
RawDisk	S0364	Driver used by the Albania wiper	[46]
PowGoop, Small Sieve, Mori, POWERSTATS	S1046, S1035, S1047, S0223	MuddyWater tools in AA22-055A	[20]
KEYPLUG, DEADEYE	S1051, S1052	APT41 tools in C0017	[21][124]
Impacket	S0357	Defense Industrial Base intrusion	[2]
Mimikatz, PsExec, ngrok	S0002, S0029, S0508	Federal agency Log4Shell intrusion	[68]
China Chopper	S0020	Web shell installed through the August Exchange flaws	[59]
Backdoor.Oldrea	S0093	Havex alias, in AA22-083A	[25][124]

Object	Id and library page	Tie to the 2022 record	Source
Neo-reGeorg	S1189	Named in the library's C0034 description	[129]
RedLine Stealer	S1240	DEV-0537 initial access	[23]
Conti	S0575	Costa Rica (April); reward (6 May); Hydra proceeds	[32][28]
REvil	S0496	FSB raids (14 Jan); Sodinokibi alias in Hydra proceeds	[8][28][124]
Ryuk	S0446	Hydra proceeds	[28]
Cuba	S0625	AA22-335A	[70]
LockBit 2.0	S1199	DEV-0401 affiliate in Microsoft's RaaS profile	[80]
LockBit 3.0	S1202	Emerged March 2022; builder leaked September 2022	[82]
BlackCat	S1068	ALPHV alias; second among IC3's critical infrastructure variants	[86][124]
Play	G1040	OWASSRF intrusions (CrowdStrike, Dec; binding Inferred)	[92][124]
Playcrypt	S1162	Play's ransomware (binding Inferred)	[92][124]

No ATT&CK object in the library covers Karakurt, MedusaLocker, Maui, Zeppelin, Vice Society, Daixin Team, Hive, IsaacWiper, FoxBlade, MagicWeb, TraderTraitor, CovalentStealer or Killnet (Demonstrated [124]). The library's Medusa Group (G1051) and Medusa Ransomware (S1244) are not bound to MedusaLocker, because no opened source ties them (Inferred). ATT&CK's C0022 Operation Dream Job covers 2019 to 2020, not TAG's 2022 activity under the same name, so it is not bound (Demonstrated [124]). The library's C0051 APT28 Nearest Neighbor Campaign starts in February 2022 and C0012 Operation CuckooBees runs to May 2022, but their primaries were not opened, so neither is bound (Demonstrated [124]).

CWE and CAPEC

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-917 Improper Neutralization of Special Elements used in an Expression Language Statement	CVE-2022-26134 (NVD); CVE-2021-44228 (NVD)	None in the library	[115][127]
CWE-502 Deserialization of Untrusted Data	CVE-2022-41082; CVE-2021-44228	CAPEC-586 Object Injection	[59][115][127]
CWE-918 Server-Side Request Forgery	CVE-2022-41040	CAPEC-664 Server Side Request Forgery	[59][127]
CWE-306 Missing Authentication for Critical Functionality	CVE-2022-1388	CAPEC-12, CAPEC-166, CAPEC-216, CAPEC-36, CAPEC-62	[91][127]
CWE-288 Authentication Bypass Using an Alternate Path or Channel	CVE-2022-40684 (Fortinet)	CAPEC-127, CAPEC-665	[62][127]
CWE-287 Improper Authentication	CVE-2022-40684 (NVD)	CAPEC-115 Authentication Bypass, one of ten the library relates; the pick is this study's (Inferred)	[115][127]
CWE-94 Improper Control of Generation of Code	CVE-2022-22965 (NVD)	CAPEC-242, CAPEC-35, CAPEC-77	[26][127]
CWE-122 Heap-based Buffer Overflow	CVE-2022-42475 (Fortinet)	CAPEC-92, as the library relates it	[71][127]
CWE-416 Use After Free	CVE-2022-0609	None in the library	[89][127]
CWE-787 Out-of-bounds Write	CVE-2022-42475 (NVD), with CWE-197	None in the library	[115][127]
CWE-20, CWE-400	CVE-2021-44228 (NVD lists both with CWE-502 and CWE-917)	Many related CAPEC in the library; none is a clear fit, so none is bound here	[115][127]
NVD-CWE-noinfo	CVE-2022-30190 (Follina)	n/a	[37]

The library's technique-to-CAPEC bindings for this year's techniques: T1078 to CAPEC-560, T1110.001 to CAPEC-49, T1133 to CAPEC-555, T1566.001 to CAPEC-163, T1558.003 to CAPEC-509 and T1021.002 to CAPEC-561 (Demonstrated [127]). The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Examples of the library's mappings to this study's techniques (technique_to_d3fend.json)	2022 guidance it matches	Source
Multi-factor Authentication	T1003.003, T1110.001, T1110.003, T1528, T1550.001	MFA on all accounts and VPNs (AA22-117A, AA22-131A)	[126][88][118]
Credential Hardening	T1003.003, T1110.001, T1110.003, T1528, T1550.001	The password-guessed dormant account in AA22-074A (pairing Inferred)	[126][22]
Credential Rotation	T1003.003, T1110.001, T1110.003, T1528, T1550.001	Uber's password resets and key rotation	[126][57]
Token Binding	T1528, T1550.001	Stolen OAuth tokens at Heroku and GitHub (pairing Inferred)	[126][96][95]
Change Default Password	T1078, T1098, T1110.001, T1110.003, T1136.002	Default MFA settings on a dormant account in AA22-074A (pairing Inferred)	[126][22]
Account Locking	T1078, T1098, T1136.002	The dormant account was unenrolled from MFA but not disabled in Active Directory (AA22-074A)	[126][22]
User Account Permissions	T1078, T1098, T1136.002	Least privilege for MSP accounts (AA22-131A)	[126][118]
Domain Account Monitoring	T1136.002	The rogue domain admin in AA22-320A	[126][68]
Web Session Access Mediation	T1003.001, T1556, T1621	Risk-based conditional access against MFA spamming (DEV-0537)	[126][23]
Session Termination	T1021.001, T1133, T1199	Support-vendor and VPN sessions (pairing Inferred)	[126][9]
Inbound Traffic Filtering	T1190, T1566.001	Exploited edge appliances (pairing Inferred)	[126][29]
Network Traffic Filtering	T1021.001, T1110.003, T1190, T1199, T1550.001, T1558.003, T1566.001, T1567.002	Restricting exposed RDP; blocking obsolete protocols at the edge	[126][69][60]
Process Segment Execution Prevention	T1190, T1203	Memory-safety exploits such as CVE-2022-0609 (pairing Inferred)	[126][89]
Kernel-based Process Isolation	T1003.001, T1505.003, T1556, T1621	Antivirus stopped the LSASS dump attempt in AA22-320A (pairing Inferred)	[126][68]
Process Spawn Analysis	T1003.001, T1505.003, T1556, T1621	Web shells on Exchange (pairing Inferred)	[126][59]

Countermeasure	Examples of the library's mappings to this study's techniques (`technique_to_d3fend.json`)	2022 guidance it matches	Source
File Integrity Monitoring	T1486, T1505.003, T1566.001	Verifying update integrity (AA22-057A)	[126][17]
Restore File	T1486, T1505.003, T1566.001	Offline, immutable, tested backups	[126][69][70]
Decoy File	T1486, T1505.003, T1566.001	Early ransomware detection (pairing Inferred)	[126]
Disk Partitioning	T1561.002	Wipers that target disk structures (pairing Inferred)	[126][4]
Software Update	T1072, T1195.001, T1195.002, T1490, T1542.001	KEV-first patching in the 2022 advisories; the library does not bind it to T1190	[126][69]
Software Inventory	T1195.001, T1490	BOD 23-01 asset discovery	[126][109]
Asset Vulnerability Enumeration	T1195.001, T1490	BOD 23-01 vulnerability enumeration every 14 days	[126][109]
Email Filtering	T1566.001	Phishing attachments in Karakurt and Hive intrusions	[126][81][69]
Decoy Network Resource	T1491.002	Website defacements (pairing Inferred)	[126][5]

Gaps in the library's map: it does not bind Multi-factor Authentication to T1078, T1133 or T1621, and does not bind Software Update to T1190, though the 2022 advisories name MFA and patching as the top controls for exactly those techniques (Inferred [126]). T1059.001, T1485, T1495, T1498, T1530, T1556.007, T1598.003 and T1685 have no D3FEND row at all (Demonstrated [126]).

Navigator layers

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chronicle-2022.json, and the ICS rows as navigator/case-studies/chronicle-2022-ics.json, both listed on the Navigator layers page. Open the Enterprise layer in the ATT&CK Navigator. Both are pinned to ATT&CK v20 and checked against the library's technique profiles with `scripts/validate_navigator.py` (Demonstrated [130]). Scores show the basis, not severity: 100 where an opened source prints the id and 70 where the source describes the behavior and this study assigns the id. Each entry's comment names the source numbers above, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

- **Destruction came back at scale.** Wipers, a modem wiper by management command, a grid attempt and a grid outage all fell within ten months (Confirmed [17][19][31][63]). See Threat Actors and Malware Families.

- **Identity beat software.** Several of the best-known breaches (Inferred) came through people and their sessions, not code flaws (Confirmed [23][57][50][42]). The control that worked was the one that cannot be phished (Confirmed [48]).
- **The management plane is the crown jewel.** KA-SAT's management segment, Okta's support tools, MSPs and AD FS servers (MagicWeb) gave reach over many victims at once (Confirmed [19][9][118][53]; Inferred for the theme).
- **Old flaws, long dwell.** A 2019 SharePoint flaw opened Albania, a 2018 FortiOS flaw headed AA23-215A's list for 2022, and intruders stayed for a year or more (Confirmed [45][87][46][2]).
- **Money became the policy lever.** Sanctions moved from people to infrastructure: a darknet market, an exchange, two mixers (Confirmed [28][24][49]).
- **Attribution came faster, but not on day one.** WhisperGate was tied to Russian military intelligence by the NCSC within four months, though Microsoft took 17 months to name its group; Viasat and Albania were attributed by governments within months (Confirmed [5][4][7][6][76]).

What is overstated and what is understated

- **Overstated: Log4Shell as a catastrophe in 2022.** The CSRB found exploitation lower than many experts predicted and knew of no significant attacks on critical infrastructure, even as it called Log4j endemic (Confirmed [106]).
- **Overstated: the CWE Top 25 as a guide to exploited weaknesses.** The KEV-only ranking differs sharply (Confirmed [116]).
- **Overstated: the precision of the advisories' technique tables.** They use ATT&CK v10 and v11 ids that v20 has revoked, and one prints the wrong name for an ICS id (Demonstrated [122][123]).
- **Overstated: first estimates and early labels.** Okta's 366 customers became two tenants; OpenSSL's Critical became High; the March KEV spike was backfill (Confirmed [9][67]; Inferred [27]).
- **Overstated: attribution in victim statements.** Uber's link to LAPSUS$ is a belief (Confirmed [57]).
- **Overstated: wiper attribution on the day.** ESET named no actor for HermeticWiper, Microsoft named no group for WhisperGate until 2023, and Viasat named none (Confirmed [16][4][7][19]; Inferred for the reading).
- **Understated: identity-only extortion.** LAPSUS$ deployed no ransomware, so ransomware-centric counts miss it (Confirmed [23]).
- **Understated: reporting gaps.** The CSRB notes Log4j exploitation data is often not collected, IC3 counts complaints only, and the advisories give FBI totals "as of" a date (Confirmed [106][86][69]).
- **Understated: dwell time.** Fourteen months in Albania, a year at a defense contractor, and months before the federal Log4Shell case was found (Confirmed [46][2][68]).
- **Understated: the Ukraine record.** Microsoft counted more than 237 operations, while public primaries describe a handful in technical detail, and the October power disruption was only published in 2023 (Confirmed [36][63]).
- **Understated: healthcare and education.** Most victims published no primary statement; the Maui, Daixin and Vice Society advisories stand in for many unnamed incidents (Confirmed [44][66][55]; Inferred for the reading). See the healthcare threat actor watchlist.

Discrepancies in the record

- **Harmony's date.** Harmony gives 05:30 PST on 23 June; Treasury dates the heist 24 June (Confirmed [40][49]). The gap is likely a time-zone difference (Inferred).
- **Viasat's scope.** Viasat's page as opened at news.viasat.com says a majority of active modems in Ukraine were disabled, along with many elsewhere in Europe; the version at viasat.com speaks of several thousand customers in Ukraine and tens of thousands elsewhere (Confirmed [19]).
- **Okta's count.** 366 customers on 22 March; two tenants in the concluded investigation (Confirmed [9]).
- **CVE-2022-40684's weakness.** Fortinet gives CWE-288; NVD lists CWE-287 and names CWE-288 in its description (Confirmed [62][115]).
- **CVE-2022-42475's weakness.** Fortinet gives CWE-122; NVD lists CWE-197 and CWE-787 (Confirmed [71][115]).
- **AA22-103A's label.** T0837 printed as Loss of Safety; the library's data names it Loss of Protection (Demonstrated [123]).
- **Exchange timing.** The flaws were exploited in August, listed in KEV on 30 September, and patched on 8 November (Confirmed [59][27]).
- **The Chrome dates.** TAG says Google patched CVE-2022-0609 on 14 February; KEV lists it on 15 February (Confirmed [3][27]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers (LastPass's notice, Uber's statement, the FTC release and the SEC release); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	ICRC, "Cyber-attack on ICRC: What we know"	icrc.org	2026-11-11	Confirmed
2	CISA, AA22-277A, Impacket and a custom exfiltration tool against a Defense Industrial Base organization, 4 Oct 2022	cisa.gov	2026-11-11	Confirmed
3	Google TAG, "Countering threats from North Korea", 24 Mar 2022	blog.google	2026-11-11	Confirmed
4	Microsoft Security, "Destructive malware targeting Ukrainian organizations", 15 Jan 2022	microsoft.com	2026-11-11	Confirmed
5	UK NCSC, Russia behind cyber attack with Europe-wide impact an hour before Ukraine invasion, 10 May 2022	ncsc.gov.uk	2026-11-11	Confirmed
6	UK FCDO, Russia behind cyber-attack with Europe-wide impact an hour before Ukraine invasion, 10 May 2022	gov.uk	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
7	Microsoft Security, "Cadet Blizzard emerges as a novel and distinct Russian threat actor", 14 Jun 2023	microsoft.com	2026-11-11	Confirmed
8	FSB, press statement on the REvil criminal community, 14 Jan 2022	fsb.ru	2026-11-11	Confirmed
9	Okta, "Okta concludes its investigation into the January 2022 compromise", 20 Apr 2022	okta.com	2026-11-11	Confirmed
10	Wormhole, incident report 02/02/22	wormholecrypto.medium.com	2026-11-11	Confirmed
11	Microsoft Security, "ACTINIUM targets Ukrainian organizations", 4 Feb 2022	microsoft.com	2026-11-11	Confirmed
12	CISA, AA22-047A, Russian state-sponsored actors and cleared defense contractors, 16 Feb 2022	cisa.gov	2026-11-11	Confirmed
13	NCSC, CISA, FBI and NSA, AA22-054A, New Sandworm malware Cyclops Blink replaces VPNFilter, 23 Feb 2022	cisa.gov	2026-11-11	Confirmed
14	UK NCSC, "New Sandworm malware Cyclops Blink replaces VPNFilter", 23 Feb 2022	ncsc.gov.uk	2026-11-11	Confirmed
15	UK NCSC, joint advisory on Cyclops Blink, 23 Feb 2022	ncsc.gov.uk	2026-11-11	Confirmed
16	ESET WeLiveSecurity, "HermeticWiper: New data-wiping malware hits Ukraine", 24 Feb 2022	welivesecurity.com	2026-11-11	Confirmed
17	CISA, AA22-057A, destructive malware against organizations in Ukraine, 26 Feb 2022, updated 1 Mar and 28 Apr 2022	cisa.gov	2026-11-11	Confirmed
18	Microsoft On the Issues, on cyberattacks in the war in Ukraine, 28 Feb 2022	blogs.microsoft.com	2026-11-11	Confirmed
19	Viasat, "KA-SAT Network cyber attack overview", 30 Mar 2022 (also at news.viasat.com)	viasat.com	2026-11-11	Confirmed
20	FBI, CISA, CNMF, NCSC-UK and NSA, AA22-055A, Iranian government-sponsored actors (MuddyWater), 24 Feb 2022	cisa.gov	2026-11-11	Confirmed
21	Mandiant (Google Cloud), "Does This Look Infected? A Summary of APT41 Targeting U.S. State Governments", 8 Mar 2022	cloud.google.com	2026-11-11	Confirmed
22	CISA, AA22-074A, Russian state-sponsored actors, default MFA protocols and PrintNightmare, 15 Mar 2022	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
23	Microsoft Security, "DEV-0537 criminal actor targeting organizations for data exfiltration and destruction", 22 Mar 2022	microsoft.com	2026-11-11	Confirmed
24	US Treasury, press release jy0768, Blender.io sanctions, 6 May 2022	home.treasury.gov	2026-11-11	Confirmed
25	CISA, FBI and DOE, AA22-083A, Tactics of state-sponsored Russian actors against the energy sector, 24 Mar 2022	cisa.gov	2026-11-11	Confirmed
26	Spring, "Spring Framework RCE, Early Announcement", 31 Mar 2022	spring.io	2026-11-11	Confirmed
27	CISA, Known Exploited Vulnerabilities catalog feed (version 2026.11.10); counts computed from the feed	cisa.gov	2026-11-11	Confirmed
28	US Treasury, press release jy0701, Hydra and Garantex sanctions, 5 Apr 2022	home.treasury.gov	2026-11-11	Confirmed
29	CISA, ED 22-03 Mitigate VMware Vulnerabilities, 18 May 2022	cisa.gov	2026-11-11	Confirmed
30	CISA, AA22-138B, exploitation of the VMware flaws, 18 May 2022	cisa.gov	2026-11-11	Confirmed
31	ESET WeLiveSecurity, "Industroyer2: Industroyer reloaded", 12 Apr 2022	welivesecurity.com	2026-11-11	Confirmed
32	US State Department (2021 to 2025 archive), reward offers for Conti ransomware co-conspirators, 6 May 2022	2021-2025.state.gov	2026-11-11	Confirmed
33	DOE, CISA, NSA and FBI, AA22-103A, APT cyber tools targeting ICS/SCADA devices, 13 Apr 2022, revised 25 May 2022	cisa.gov	2026-11-11	Confirmed
34	FBI, CISA and Treasury, AA22-108A, TraderTraitor, 18 Apr 2022, revised 20 Apr 2022	cisa.gov	2026-11-11	Confirmed
35	Five Eyes, AA22-110A, Russian state-sponsored and criminal cyber threats to critical infrastructure, 20 Apr 2022, revised 9 May 2022	cisa.gov	2026-11-11	Confirmed
36	Microsoft On the Issues, on the hybrid war in Ukraine, 27 Apr 2022	blogs.microsoft.com	2026-11-11	Confirmed
37	NVD, CVE-2022-30190 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
38	Atlassian, Confluence Security Advisory 2022-06-02	confluence.atlassian.com	2026-11-11	Confirmed
39	NSA, CISA and FBI, AA22-158A, PRC state-sponsored actors exploit network providers and devices, 7 Jun 2022	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
40	Harmony, "Harmony's Horizon Bridge Hack"	medium.com	2026-11-11	Confirmed
41	CISA and USCG, AA22-174A, Malicious cyber actors continue to exploit Log4Shell in VMware Horizon systems, 23 Jun 2022, revised 18 Jul 2022	cisa.gov	2026-11-11	Confirmed
42	Twilio, "August 2022 social engineering attack", final update 27 Oct 2022 (also at twilio.com/blog)	twilio.com	2026-11-11	Confirmed
43	CISA, AA22-181A, MedusaLocker ransomware, 30 Jun 2022	cisa.gov	2026-11-11	Confirmed
44	FBI, CISA and Treasury, AA22-187A, North Korean state-sponsored actors use Maui ransomware, 6 Jul 2022	cisa.gov	2026-11-11	Confirmed
45	Microsoft Security, "Microsoft investigates Iranian attacks against the Albanian government", 8 Sep 2022	microsoft.com	2026-11-11	Confirmed
46	FBI and CISA, AA22-264A, Iranian state actors conduct cyber operations against the Government of Albania, 21 Sep 2022, revised 23 Sep 2022	cisa.gov	2026-11-11	Confirmed
47	Twitter Privacy Center, "An issue affecting some anonymous accounts", 5 Aug 2022 (also at privacy.x.com)	privacy.twitter.com	2026-11-11	Confirmed
48	Cloudflare blog, on the SMS phishing attacks of July 2022	blog.cloudflare.com	2026-11-11	Confirmed
49	US Treasury, press release jy0916, Tornado Cash sanctions, 8 Aug 2022	home.treasury.gov	2026-11-11	Confirmed
50	Cisco Talos, report on the recent cyber attack on Cisco, 10 Aug 2022	blog.talosintelligence.com	2026-11-11	Confirmed
51	CISA, AA22-223A, Zeppelin ransomware, 11 Aug 2022	cisa.gov	2026-11-11	Confirmed
52	CISA, AA22-228A, exploited CVEs in Zimbra Collaboration Suite, 16 Aug 2022	cisa.gov	2026-11-11	Confirmed
53	Microsoft Security, "MagicWeb: NOBELIUM's post-compromise trick to authenticate as anyone", 24 Aug 2022	microsoft.com	2026-11-11	Confirmed
54	LastPass, "Notice of recent security incident", 25 Aug 2022, updated 22 Dec 2022 (also at `https://blog.lastpass.com/2022/12/notice-of-recent-security-incident/`)	`https://blog.lastpass.com/posts/notice-of-recent-security-incident`	2026-11-11	Confirmed
55	FBI, CISA and MS-ISAC, AA22-249A, Vice Society, 6 Sep 2022	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
56	CISA, AA22-257A, IRGC-affiliated actors, data extortion and disk encryption, 14 Sep 2022	cisa.gov	2026-11-11	Confirmed
57	Uber, "Security update", 15 to 19 Sep 2022	`https://www.uber.com/newsroom/security-update/`	2026-11-11	Confirmed
58	OAIC, Australian Information Commissioner takes civil penalty action against Optus	oaic.gov.au	2026-11-11	Confirmed
59	Microsoft Security, "Analyzing attacks using the Exchange vulnerabilities CVE-2022-41040 and CVE-2022-41082", 30 Sep 2022	microsoft.com	2026-11-11	Confirmed
60	NSA, CISA and FBI, AA22-279A, Top CVEs actively exploited by PRC state-sponsored actors, 6 Oct 2022	cisa.gov	2026-11-11	Confirmed
61	BNB Chain, "BNB Chain ecosystem update", October 2022	bnbchain.org	2026-11-11	Confirmed
62	Fortinet PSIRT, FG-IR-22-377 (CVE-2022-40684), 10 Oct 2022	fortiguard.com	2026-11-11	Confirmed
63	Mandiant (Google Cloud), on Sandworm's disruption of power in Ukraine through operational technology, 2023	cloud.google.com	2026-11-11	Confirmed
64	Microsoft Security, "New 'Prestige' ransomware impacts organizations in Ukraine and Poland", 14 Oct 2022, updated Nov 2022	microsoft.com	2026-11-11	Confirmed
65	OAIC, OAIC takes civil penalty action against Medibank, 5 Jun 2024	oaic.gov.au	2026-11-11	Confirmed
66	FBI, CISA and HHS, AA22-294A, Daixin Team, 21 Oct 2022	cisa.gov	2026-11-11	Confirmed
67	OpenSSL, Security Advisory 1 Nov 2022	openssl.org	2026-11-11	Confirmed
68	CISA, AA22-320A, Iranian government-sponsored APT actors and a federal network, 16 Nov 2022	cisa.gov	2026-11-11	Confirmed
69	FBI, CISA and HHS, AA22-321A, Hive ransomware, 17 Nov 2022	cisa.gov	2026-11-11	Confirmed
70	CISA, AA22-335A, Cuba ransomware, 1 Dec 2022	cisa.gov	2026-11-11	Confirmed
71	Fortinet PSIRT, FG-IR-22-398 (CVE-2022-42475), 12 Dec 2022	fortiguard.com	2026-11-11	Confirmed
72	Citrix, "Critical security update now available for Citrix ADC, Citrix Gateway", 13 Dec 2022	citrix.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
73	Google TAG, "Fog of war: how the Ukraine conflict transformed the cyber threat landscape", 16 Feb 2023	blog.google	2026-11-11	Confirmed
74	CISA, FBI and NSA, AA22-011A, Russian state-sponsored threats to US critical infrastructure, 11 Jan 2022, revised 1 Mar 2022	cisa.gov	2026-11-11	Confirmed
75	Microsoft On the Issues, on the STRONTIUM domain takeover and cyberattacks on Ukraine, 7 Apr 2022	blogs.microsoft.com	2026-11-11	Confirmed
76	US Treasury, press release jy0941, MOIS sanctions, 9 Sep 2022	home.treasury.gov	2026-11-11	Confirmed
77	US Treasury, press release jy0948, IRGC-affiliated ransomware sanctions, 14 Sep 2022	home.treasury.gov	2026-11-11	Confirmed
78	OFAC, recent actions, 14 Apr 2022	ofac.treasury.gov	2026-11-11	Confirmed
79	CISA, FBI, NSA and partners, AA22-040A, 2021 trends show increased globalized threat of ransomware, 9 Feb 2022	cisa.gov	2026-11-11	Confirmed
80	Microsoft Security, "Ransomware as a service: Understanding the cybercrime gig economy", 9 May 2022	microsoft.com	2026-11-11	Confirmed
81	CISA, AA22-152A, Karakurt data extortion group, 1 Jun 2022	cisa.gov	2026-11-11	Confirmed
82	CISA and partners, AA23-165A, Understanding ransomware threat actors: LockBit, 2023	cisa.gov	2026-11-11	Confirmed
83	US Treasury, press release jy2041, sanctions on the Medibank attacker, 23 Jan 2024	home.treasury.gov	2026-11-11	Confirmed
84	FinCEN, analysis of ransomware reporting in BSA filings, 1 Nov 2022	fincen.gov	2026-11-11	Confirmed
85	The White House (archive), International Counter Ransomware Initiative 2022 joint statement, 1 Nov 2022	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
86	FBI IC3, 2022 Internet Crime Report	ic3.gov	2026-11-11	Confirmed
87	CISA and partners, AA23-215A, 2022 top routinely exploited vulnerabilities, 2023	cisa.gov	2026-11-11	Confirmed
88	CISA and partners, AA22-117A, 2021 top routinely exploited vulnerabilities, 27 Apr 2022, revised 28 Apr 2022	cisa.gov	2026-11-11	Confirmed
89	NVD, CVE-2022-0609 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
90	VMware, VMSA-2022-0011, 6 Apr 2022	vmware.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
91	NVD, CVE-2022-1388 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
92	CrowdStrike, OWASSRF exploit analysis and recommendations, 20 Dec 2022	crowdstrike.com	2026-11-11	Confirmed
93	NVD, CVE-2022-27518 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
94	NVD, CVE-2022-47966 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
95	GitHub, security alert on stolen OAuth user tokens, 15 Apr 2022, final 27 Apr 2022	github.blog	2026-11-11	Confirmed
96	Heroku, "April 2022 incident review"	heroku.com	2026-11-11	Confirmed
97	PyTorch, on the compromised nightly dependency, 25 to 30 Dec 2022	pytorch.org	2026-11-11	Confirmed
98	Slack, "Slack security update", 31 Dec 2022	slack.com	2026-11-11	Confirmed
99	MSRC, "Investigation regarding misconfigured Microsoft storage location", 19 Oct 2022	microsoft.com	2026-11-11	Confirmed
100	Optus, "Optus notifies customers of cyberattack", 22 Sep 2022	optus.com.au	2026-11-11	Confirmed
101	FTC, action against Drizly and its CEO over security failures, 24 Oct 2022	`https://www.ftc.gov/news-events/news/press-releases/2022/10/ftc-takes-action-against-drizly-its-ceo-james-cory-rellas-security-failures-exposed-data-25-million`	2026-11-11	Confirmed
102	GovInfo, Public Law 117-103, Consolidated Appropriations Act, 2022 (Division Y, CIRCIA), 15 Mar 2022	govinfo.gov	2026-11-11	Confirmed
103	CISA, Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA)	cisa.gov	2026-11-11	Confirmed
104	SEC, press release 2022-39, proposed cybersecurity disclosure rules, 9 Mar 2022	`https://www.sec.gov/news/press-release/2022-39`	2026-11-11	Confirmed
105	The White House (archive), statement by the President on the nation's cybersecurity, 21 Mar 2022	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
106	Cyber Safety Review Board, report on Log4j, 11 Jul 2022	cisa.gov	2026-11-11	Confirmed
107	OMB, M-22-18 on secure software development practices, 14 Sep 2022	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
108	European Commission, Cyber Resilience Act proposal, 15 Sep 2022	ec.europa.eu	2026-11-11	Confirmed
109	CISA, BOD 23-01 Improving asset visibility and vulnerability detection on federal networks, 3 Oct 2022	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
110	The White House (archive), Executive Order 14086 on signals intelligence safeguards, 7 Oct 2022	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
111	CISA, Cross-Sector Cybersecurity Performance Goals, 2022 edition	cisa.gov	2026-11-11	Confirmed
112	legislation.gov.uk, Product Security and Telecommunications Infrastructure Act 2022 (c. 46), 6 Dec 2022	legislation.gov.uk	2026-11-11	Confirmed
113	GovInfo, Public Law 117-260, Quantum Computing Cybersecurity Preparedness Act, 21 Dec 2022	govinfo.gov	2026-11-11	Confirmed
114	European Commission, NIS2 Directive policy page	digital-strategy.ec.europa.eu	2026-11-11	Confirmed
115	NVD, CVE-2022-26134 record (API), and the NVD records of the other headline CVEs named in Part 6	services.nvd.nist.gov	2026-11-11	Confirmed
116	MITRE CWE, 2022 CWE Top 25 Most Dangerous Software Weaknesses	cwe.mitre.org	2026-11-11	Confirmed
117	CISA, fact sheet "Implementing Phishing-Resistant MFA", Oct 2022	cisa.gov	2026-11-11	Confirmed
118	Five Eyes and JCDC, AA22-131A, Protecting against cyber threats to managed service providers and their customers, 11 May 2022	cisa.gov	2026-11-11	Confirmed
119	MITRE ATT&CK, campaign C0034, 2022 Ukraine Electric Power Attack (content v20.1)	attack.mitre.org	2026-11-11	Confirmed
120	MITRE ATT&CK, updates October 2022 (v12)	attack.mitre.org	2026-11-11	Confirmed
121	MITRE ATT&CK, technique T1685 Disable or Modify Tools (content v20.1)	attack.mitre.org	2026-11-11	Confirmed
122	TeamStarWolf library, `data/attack/superseded_by.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
123	TeamStarWolf library, `data/attack/ics/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
124	TeamStarWolf library, ATT&CK group, software and campaign data (`data/attack/`) and generated pages (`mitre/`)	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
125	TeamStarWolf library, `data/attack/group_to_technique.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
126	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

#	Source	URL	Opened	Grade
127	TeamStarWolf library, `data/weaknesses/cwe.jsonl` and the CAPEC pages under `mitre/capec/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
128	TeamStarWolf library, generated page for S1125 AcidRain	raw.githubusercontent.com	2026-11-11	Reported
129	TeamStarWolf library, generated page for campaign C0034	raw.githubusercontent.com	2026-11-11	Confirmed
130	TeamStarWolf library, `scripts/validate_navigator.py`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
131	TeamStarWolf library, generated page for S1072 Industroyer2	raw.githubusercontent.com	2026-11-11	Reported

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense Reference, Edge Device Security Reference, ICS/OT Security Reference, ICS ATT&CK Atlas, Cloud Attack Reference, Supply Chain Security, Vulnerability Prioritization Reference, Incident Response Reference
- Home studies: Sandworm; Russia-attributed actors; Iran-attributed actors; North Korea-attributed actors; China-attributed actors; APT41: the public record; Log4Shell; npm supply-chain attacks
- Related studies: The Ransomware Ecosystem; SolarWinds and SUNBURST; Healthcare threat actor watchlist; Stuxnet; ICS attacks and advisories, 2024 to 2026; Hugging Face supply chain; Exchange Marauder, 2021
- Series: 2016, 2017, 2019, 2020, 2021
- Groups: G0034 Sandworm Team, G1003 Ember Bear, G0007 APT28, G0016 APT29, G0047 Gamaredon Group, G0035 Dragonfly, G0088 TEMP.Veles, G1004 LAPSUS$, G0102 Wizard Spider, G0069 MuddyWater, G1055 VOID MANTICORE, G0059 Magic Hound, G0032 Lazarus Group, G0082 APT38, G0096 APT41
- Campaigns: C0034 2022 Ukraine Electric Power Attack, C0038 HomeLand Justice, C0017, C0030 Triton Safety Instrumented System Attack

- Software: S0689 WhisperGate, S0697 HermeticWiper, S0698 HermeticWizard, S0693 CaddyWiper, S1072 Industroyer2, S0687 Cyclops Blink, S1125 AcidRain, S1058 Prestige, S1151 ZeroCleare, S0575 Conti, S0496 REvil, S0625 Cuba, S1202 LockBit 3.0, S1068 BlackCat
- Techniques: T1190 Exploit Public-Facing Application, T1133 External Remote Services, T1078 Valid Accounts, T1621 Multi-Factor Authentication Request Generation, T1199 Trusted Relationship, T1556.007 Hybrid Identity, T1495 Firmware Corruption, T1561.002 Disk Structure Wipe, T1485 Data Destruction, T1486 Data Encrypted for Impact, T1657 Financial Theft, T1685 Disable or Modify Tools
- CAPEC: CAPEC-586, CAPEC-664, CAPEC-115, CAPEC-560, CAPEC-555
- Navigator layers, including this study's layers, chronicle-2022.json and chronicle-2022-ics.json